S O C O P E R A T I O N S M A N U A L

INCIDENT RESPONSE PLAYBOOK

Malware Infection

Companion Documentation & Operations Manual

Classification	Public Release
Document Type	SOC Operations Manual / SOP
Playbook Version	v1.0
Framework	NIST SP 800-61r2 | MITRE ATT&CK v14
Scope	Malware Infection Incidents
Applicable To	SOC L1 / L2 / L3 | IR Team | IT Security
Doc Date	June 2026
Author	BlueShield Team

Table of Contents

1 Document Control
- 1.1 Document Purpose
- 1.2 Target Audience
- 1.3 Scope
- 1.4 Assumptions
- 1.5 Version History
- 1.6 Approval Matrix
- 1.7 Distribution List

2 Executive Summary
- 2.1 The Malware Threat Landscape
- 2.2 Business Value of This Playbook
- 2.3 Alignment with Organizational Security Strategy

3 Playbook Architecture

4 Detailed Phase Documentation
- 4.1 Phase 1 — Preparation
- 4.2 Phase 2 — Detection & Identification
- 4.3 Phase 3 — Analysis & Investigation
- 4.4 Phase 4 — Remediation: Containment, Eradication & Recovery
- 4.5 Phase 5 — Post-Incident Activities

5 Workflow Explanation

6 Decision Tree Documentation

7 MITRE ATT&CK Documentation

8 IOC Collection Documentation

9 Escalation Documentation

10 Tools Documentation

11 Roles Documentation — RACI Matrix

12 Operational Guidelines

13 Key Performance Indicators (KPIs)

14 Risks and Limitations

15 Continuous Improvement

16 Frequently Asked Questions (20 FAQs)

17 Glossary

18 Appendices
- 18.A Master Incident Response Checklist
- 18.B Daily Analyst Shift Checklist
- 18.C Analyst Quick Reference Card

1. Document Control

This section establishes the administrative framework governing this documentation package. All personnel referencing this document must review and acknowledge the information contained herein.

1.1 Document Purpose

This Operations Manual serves as the authoritative companion documentation to the Incident Response Playbook for Malware Infection (v1.0). Its purpose is threefold:

- To provide SOC analysts and incident responders with comprehensive procedural guidance that expands upon the playbook's structured steps.
- To ensure consistent, repeatable, and audit-ready incident response execution across all tiers of the Security Operations Center.
- To serve as a training reference for onboarding new analysts and validating team readiness through tabletop exercises.

1.2 Target Audience

Role	Usage	Access Level
SOC Analyst (L1)	Daily operational reference during alert triage	Full Read
SOC Lead / L2 Analyst	Investigation guidance and escalation decisions	Full Read
Incident Commander (L3)	Oversight, authorization, and management reporting	Full Read
Threat Intelligence Team	IOC validation and MITRE ATT&CK mapping reference	Full Read
IT / Sysadmin Team	Containment and recovery procedural guidance	Sections 4–5
CISO / Management	Executive summary and KPI reporting	Sections 1–2, 13
Auditors / Compliance	Evidence of process and governance maturity	All Sections

1.3 Scope

This documentation applies to all malware infection incidents occurring within the organization's monitored environment, including:

- Endpoints: Workstations, laptops, servers, and virtual machines
- Network segments visible to the SIEM platform
- Malware categories: Trojans, Worms, RATs, Spyware, Ransomware Droppers, Fileless Malware, Rootkits, Backdoors

OUT OF SCOPE:

- Full ransomware encryption events (covered by a separate playbook)
- Mobile device malware incidents (covered by Mobile Security Playbook)

- Supply chain compromise (covered by Third-Party Risk Playbook)

1.4 Assumptions

> 📋 **NOTE** *The following assumptions must be validated before this playbook is activated. If any assumption is invalid, escalate to the SOC Lead immediately.*

1. A functional SIEM platform is deployed, with log ingestion from endpoints, network devices, and identity systems.
2. EDR agents are installed and reporting on all in-scope endpoints.
3. Analysts have been trained on the tools referenced in this document (SIEM, Volatility, Sysinternals).
4. An incident ticketing system is operational and accessible.
5. Escalation contacts are current and available (phone numbers validated within the last 30 days).
6. Forensic workstations with required toolkits are available and tested.
7. Backup systems have been tested and recovery procedures are documented.

1.5 Version History

Version	Date	Changes	Author	Status
1.0	June 2026	Initial release — full companion documentation package	Youssef	**Active**

1.6 Approval Matrix

Role	Name	Date	Signature
SOC Lead / L2 Supervisor		June 2026	
Incident Commander (L3)		June 2026	
CISO / Security Director		June 2026	

1.7 Distribution List

Team/Individual	Department	Copy Type	Date Issued
SOC Team (All Tiers)	Security Operations	Digital	June 2026
Incident Response Team	Cybersecurity	Digital	June 2026
IT Operations	Infrastructure	Digital	June 2026
CISO Office	Executive	Digital	June 2026
Compliance / Audit	Risk & Compliance	Digital	June 2026

2. Executive Summary

This section is intended for senior stakeholders, management, and CISO-level personnel who require a strategic-level understanding of the playbook's purpose and organizational value without the need to engage with technical procedural detail.

2.1 The Malware Threat Landscape

Malware remains one of the most persistent and operationally damaging threat categories faced by organizations worldwide. Modern malware campaigns — including advanced Trojans such as Emotet, Remote Access Trojans (RATs), and sophisticated fileless attack frameworks — are engineered to evade traditional security controls, establish persistent footholds, and enable prolonged dwell time within enterprise environments.

Key industry statistics underscore the urgency of a structured response capability:

- The average dwell time for malware in enterprise environments before detection can exceed 21 days, during which attackers conduct reconnaissance, escalate privileges, and exfiltrate sensitive data.
- Organizations without formal incident response playbooks experience containment times up to 3x longer than those with documented, rehearsed procedures.
- Ransomware dropper campaigns — where initial-stage malware is used to deliver destructive payloads — represent the fastest-growing attack vector targeting mid-market and enterprise environments.

2.2 Business Value of This Playbook

Business Value	Description
Risk Reduction	Documented detection rules and containment procedures reduce the probability of full-environment compromise by limiting attacker lateral movement.
Faster Mean Time to Respond (MTTR)	Structured decision trees and phase-based workflows eliminate analyst hesitation and reduce escalation delays during high-pressure incidents.
Standardization	All SOC tiers operate from a single authoritative document, eliminating inconsistent ad-hoc responses that introduce risk and reduce auditability.
Regulatory Compliance	Documented IR procedures satisfy regulatory evidence requirements (ISO 27001, NIST CSF, NCA ECC controls) demonstrating governance maturity.
Cost Containment	Early containment of malware infections prevents the escalation to ransomware encryption events, which carry average remediation costs orders of magnitude higher.
Analyst Enablement	Junior analysts (L1) operate with confidence using the decision tree, reducing unnecessary escalations and optimizing senior analyst bandwidth.

2.3 Alignment with Organizational Security Strategy

This playbook is designed to operate as an integral component of the organization's broader security operations capability, providing:

- Direct integration with SIEM alerting workflows to ensure automated alert-to-analyst hand-off is governed by documented triage procedures.
- Alignment with the MITRE ATT&CK framework to enable threat-informed defense — ensuring detection investments are prioritized against the highest-probability attack techniques.
- Support for continuous improvement through post-incident review cycles that feed detection engineering and playbook refinement.

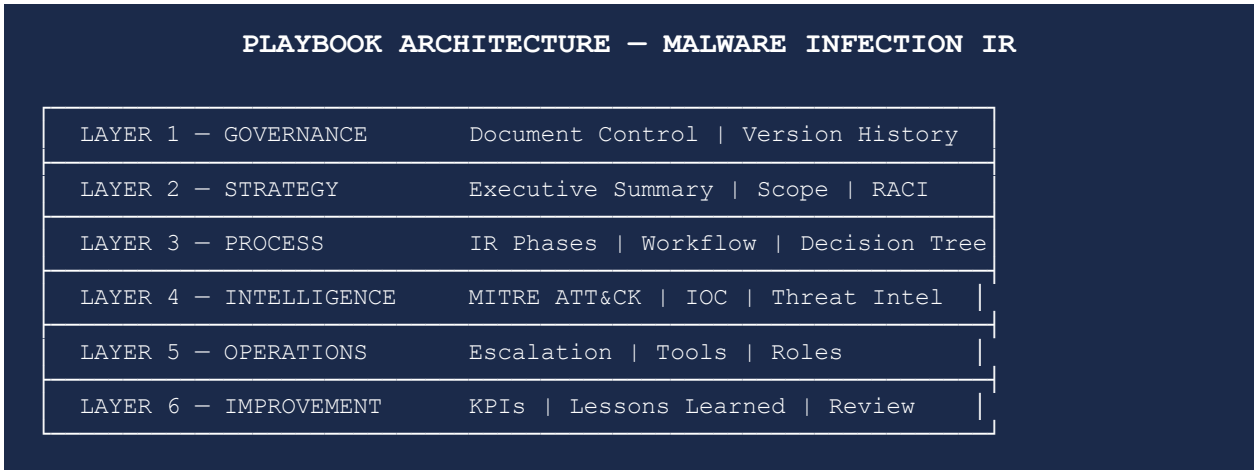
> **NOTE**
>
> *EXECUTIVE DIRECTIVE: All SOC personnel are required to complete playbook familiarization training within 30 days of onboarding. Tabletop exercises based on this playbook must be conducted no less than quarterly.*

3. Playbook Architecture

Understanding the structural design of the playbook is essential for efficient navigation during an active incident. This section describes each major component, its purpose, and how it interrelates with other sections.

3.1 Structural Overview

The playbook follows a layered architecture modeled on enterprise DFIR operational frameworks:



3.2 Section-by-Section Description

3.2.1 Playbook Overview (Section 1 of Playbook)

PURPOSE: Establishes the foundational context for the entire document.

- The Purpose subsection defines WHO uses the playbook and in WHAT context — specifically targeting SOC Analysts, Incident Responders, and IT Security teams operating within SIEM-monitored environments.
- The Malware Definition subsection provides a working taxonomy that ensures all team members operate from a consistent understanding of what constitutes malware — critical for accurate incident classification.
- The Scope subsection explicitly defines asset boundaries and malware type coverage, preventing scope creep during incident response and ensuring analysts know when a separate playbook should be invoked.
- The Severity Classification table provides immediate triage guidance with SLA commitments — enabling L1 analysts to make autonomous severity decisions within the first minutes of alert receipt.

> **TIP** *During incident triage, the Severity Classification table should be the FIRST reference point. Never spend more than 5 minutes on initial classification — use the table and proceed.*

3.2.2 Roles & Responsibilities (Section 2 of Playbook)

PURPOSE: Eliminates role ambiguity during incident response, which is one of the primary causes of delayed containment.

- Each role is mapped to specific responsibilities rather than generic ownership, ensuring clear accountability at every phase of the incident lifecycle.
- The section supports RACI (Responsible, Accountable, Consulted, Informed) governance by pre-defining who takes action versus who provides oversight.

3.2.3 Incident Response Phases (Section 3 of Playbook)

PURPOSE: Provides the core procedural backbone of the playbook, structured around the NIST SP 800-61r2 lifecycle model.

- Each phase contains specific activities, objectives, and key deliverables — ensuring analysts know what the expected output of their work is before moving to the next phase.
- The inclusion of deliverables per phase enables supervisors to verify phase completion without requiring a full technical review of all analyst actions.

3.2.4 Analyst Decision Tree (Section 5 of Playbook)

PURPOSE: Provides a structured, branching logic framework for L1 analysts to navigate from alert receipt to action determination with minimal supervisory input.

- Reduces cognitive load during high-pressure incidents by breaking complex decisions into binary YES/NO questions.
- Incorporates severity escalation logic directly within the decision flow, ensuring consistent escalation decisions across all analysts.

3.2.5 MITRE ATT&CK Mapping (Sections 6–7 of Playbook)

PURPOSE: Grounds the playbook in threat-informed defense by mapping malware behaviors to industry-standard adversary technique identifiers.

- Enables SOC teams to correlate observed behaviors with known attack patterns, accelerating investigation and enabling proactive detection tuning.
- The Coverage Heatmap provides a gap analysis tool that directly informs SIEM rule development priorities.

3.2.6 IOC Collection Checklist (Section 9 of Playbook)

PURPOSE: Standardizes the evidence collection process to ensure all relevant artifacts are captured before containment actions that may destroy forensic evidence.

- Organized by IOC category (File, Network, Host, Memory, Log, Email) to enable parallel collection across multiple analyst workstreams.

3.2.7 Escalation Matrix (Section 10 of Playbook)

PURPOSE: Removes ambiguity from escalation decisions by mapping specific incident scenarios to designated escalation targets, communication methods, and timeframes.

3.2.8 Tools Reference (Section 11 of Playbook)

PURPOSE: Ensures analysts know which tool to use at each phase, reducing time lost to tool selection decisions during active incidents.

3.2.9 Appendix — Incident Report Template

PURPOSE: Provides a standardized reporting template that ensures all incidents are documented consistently, supporting post-incident review, audit, and regulatory reporting requirements.

4. Detailed Phase Documentation

This section provides enterprise-grade operational documentation for each phase of the NIST SP 800-61r2 Incident Response Lifecycle as applied to malware infection incidents. Each phase is documented using a standardized structure to ensure completeness and operational utility.

PHASE 1 — PREPARATION

Purpose

The Preparation phase is the foundation upon which all subsequent incident response capability is built. Its purpose is to ensure that the organization possesses the people, processes, tools, and intelligence required to detect and respond to malware infection incidents effectively and within defined SLA commitments.

Objectives

- Deploy and validate all monitoring, detection, and response tooling required for malware incident handling.
- Establish and communicate roles, responsibilities, and escalation procedures across all response teams.
- Ensure forensic capability is available and tested, including memory acquisition, disk imaging, and log collection.
- Maintain current threat intelligence subscriptions and IOC repositories.
- Validate backup integrity and recovery procedures through regular testing.

Inputs

- Organizational asset inventory (critical assets prioritized)
- Prior incident lessons learned reports
- Current threat intelligence feeds (MITRE ATT&CK, CISA advisories, ISACs)
- Regulatory and compliance requirements applicable to the organization

Key Activities

SECURITY CONTROLS & MONITORING

- Deploy and validate anti-malware and EDR solutions across all in-scope endpoints — verify agent health reporting in SIEM.
- Configure SIEM correlation rules for: malware execution, PowerShell abuse, C2 beaconing, persistence mechanism creation, and lateral movement indicators.
- Implement Sysmon with the SwiftOnSecurity configuration baseline on all Windows endpoints to enable process, network, and registry event logging.
- Validate FortiGate IPS signatures are current and C2 reputation feeds are active and blocking.

INCIDENT RESPONSE READINESS

- Conduct quarterly tabletop exercises using realistic malware infection scenarios (reference Section 7 — Case Study).
- Validate escalation contact lists — phone numbers and out-of-hours contacts must be tested within 30 days.
- Prepare forensic toolkits: Sysinternals Suite, Volatility 3, FTK Imager, Wireshark — ensure tools are current versions and analysts are trained.

- Establish and document chain-of-custody procedures for all forensic evidence collection.

THREAT INTELLIGENCE

- Subscribe to and operationalize threat intelligence feeds: AlienVault OTX, CISA KEV, ISAC sector feeds.
- Maintain internal IOC repository — validate IOC freshness (decommission stale IOCs older than 90 days unless threat actor is active).
- Update SIEM detection rules with TTPs from MITRE ATT&CK v14 Navigator gap analysis.

Outputs

- Validated SIEM detection ruleset with documented coverage map
- Tested escalation contact directory
- Available and tested forensic toolkit
- Current threat intelligence repository
- Trained personnel with tabletop exercise completion records

Responsible Teams

- Primary: SOC Lead / L2 | Threat Intelligence Team
- Supporting: IT Operations | CISO Office

Expected Deliverables

- Active Security Monitoring — SIEM dashboard with malware detection rules operational
- Updated Incident Response Procedures — this document, reviewed and approved
- Defined Escalation Process — validated contact list with 24/7 coverage
- Current Threat Intelligence Sources — subscriptions active, IOC repository updated
- Trained Personnel — tabletop exercise completion certificates on file

Success Criteria

- 100% of in-scope endpoints reporting to SIEM with no gaps >24 hours
- All critical detection rules validated through purple team or detection engineering testing
- Forensic toolkit deployment test completed successfully within the last quarter

Common Mistakes

⚠ WARNING	*CRITICAL MISTAKE: Treating Preparation as a one-time activity. Detection rules decay rapidly as the threat landscape evolves. Preparation is a continuous process requiring monthly rule reviews and quarterly full assessments.*

- Failing to test backup recovery procedures — backups that have never been restored are unreliable.
- Maintaining stale escalation contacts — a contact list with outdated phone numbers will fail at the worst possible moment.
- Deploying Sysmon without a validated configuration — default Sysmon configurations generate excessive noise and degrade SIEM performance.

Metrics / KPIs

KPI	Measurement	Target
Endpoint Coverage	Endpoints reporting to SIEM / Total endpoints	> 98%

Rule Currency	Detection rules updated within 30 days	100%
Training Completion	Analysts with tabletop completion	100% quarterly
IOC Repository Freshness	IOCs reviewed within 90 days	> 95%

PHASE 2 — DETECTION & IDENTIFICATION

Purpose

The Detection phase transforms raw security telemetry into actionable incident declarations. It is during this phase that the SOC differentiates genuine malware infections from false positives, classifies incident severity, and initiates the formal incident response workflow.

Objectives

- Detect and validate malware-related security alerts from all available telemetry sources.
- Classify the incident by severity using established criteria (reference Severity Classification table in playbook Section 1.4).
- Create the incident ticket and begin evidence preservation immediately upon suspected malware confirmation.
- Escalate confirmed or high-confidence suspected infections to appropriate analyst tier.

Inputs

- SIEM correlated alerts (malware detection, behavioral anomalies, C2 indicators)
- EDR detections and process tree data
- User-reported suspicious activity tickets
- Threat intelligence IOC feeds for correlation

Key Activities

INITIAL ALERT TRIAGE (L1 RESPONSIBILITY — TARGET: < 10 MINUTES)

- Review alert details: source host, affected user, alert type, timestamp, and correlated events.
- Cross-reference alert source against whitelist — if whitelisted, close as false positive with documented justification.
- Query SIEM for all events from the affected host in the prior 24–72 hours to establish behavioral baseline.
- Check file hashes, IPs, and domains against threat intelligence feeds (VirusTotal, AlienVault OTX).

INITIAL INVESTIGATION

- Identify affected hosts, users, and accounts.
- Determine likely infection vector: Email attachment / Malicious web download / Removable media / Exploit / Credential compromise.
- Collect and preserve initial evidence: file hashes, process information, network connections, and relevant log entries.
- Assess whether multiple systems may be affected — review SIEM for similar indicators across other hosts.

INCIDENT CLASSIFICATION

- Apply severity classification criteria — Critical / High / Medium / Low — based on confirmed indicators.

- Create incident ticket with: Incident ID, Affected System, Initial Severity, Detection Source, Analyst Name, Timestamp.
- Document all findings with UTC timestamps — do NOT rely on memory for sequencing.

> **TIP** *BEST PRACTICE: Always capture screenshots of SIEM alerts before any investigation actions. Alert data can be modified by subsequent events. Screenshot immediately upon alert receipt.*

Escalation Criteria

> **WARNING** *IMMEDIATELY escalate to L2 if ANY of the following are confirmed: Active malware spreading to multiple systems | Confirmed C2 communication | Privileged account compromise | Critical server affected | Evidence of data exfiltration | Ransomware dropper activity.*

Outputs

- Incident ticket created with documented initial findings
- Initial scope assessment completed
- Evidence preserved (screenshots, log exports, hash values)
- Severity classification assigned
- Escalation decision documented

Responsible Teams

- Primary: SOC Analyst L1
- Escalation: SOC Lead / L2

Common Mistakes

- Investigating without creating a ticket first — creates audit trail gaps and risks losing investigation context.
- Spending too long on validation before escalating — if there is any evidence of C2 or lateral movement, escalate IMMEDIATELY.
- Failing to preserve the original alert data before querying — SIEM queries can alter time-based context.

Metrics / KPIs

KPI	Measurement	Target
Mean Time to Detect (MTTD)	Time from infection to SIEM alert	< 30 minutes
Mean Time to Triage	Alert receipt to ticket creation	< 10 minutes
False Positive Rate	FP closures / Total alerts	< 20%
Escalation Accuracy	Correct escalation decisions / Total escalations	> 90%

PHASE 3 — ANALYSIS & INVESTIGATION

Purpose

The Analysis phase is the investigative core of the incident response lifecycle. During this phase, L2 analysts and the Incident Commander develop a comprehensive understanding of the attack —

including the malware family, infection vector, scope of compromise, and attacker objectives — to inform an effective remediation strategy.

Objectives

- Identify malware family, capabilities, and persistence mechanisms.
- Establish a complete timeline of malicious activity from initial infection to current state.
- Determine the full scope of compromise — all affected systems, users, and data.
- Assess attacker objectives: Are they still active? Is data being exfiltrated? Is ransomware deployment imminent?
- Develop a targeted remediation plan based on confirmed findings.

Key Activities

MALWARE ANALYSIS

- Submit suspicious files to sandbox analysis platforms (Any.run, Hybrid Analysis) — observe behavior in isolated environment.
- Validate IOCs: cross-reference file hashes (MD5/SHA256), IP addresses, domains, and registry artifacts against threat intelligence.
- Identify malware persistence mechanisms using Autoruns, Registry analysis, and Sysmon event logs.
- Use Volatility 3 for memory analysis if fileless malware is suspected — extract running processes, network connections, and injected code.

SCOPE ASSESSMENT

- Establish attack timeline — map events in chronological order using SIEM log correlation.
- Query SIEM for lateral movement indicators: authentication events from the compromised host to other systems.
- Identify all systems communicating with confirmed malicious IPs/domains over the investigation window.
- Determine if data staging or exfiltration has occurred — review outbound transfer volumes and destinations.

MITRE ATT&CK MAPPING

- Map observed behaviors to MITRE ATT&CK techniques (reference playbook Section 6).
- Use ATT&CK Navigator to visualize the attack chain and identify gaps in detection coverage.
- Document technique IDs in the incident ticket to support post-incident detection tuning.

> **NOTE**
> *ANALYSIS PRINCIPLE: Follow the evidence, not the hypothesis. Analysts must document what they observe, not what they expect to find. Confirmation bias during analysis leads to missed indicators and incomplete remediation.*

Outputs

- Malware family identification and behavioral profile
- Complete incident timeline
- Validated IOC list
- Scope assessment — all affected systems and accounts
- MITRE ATT&CK technique mapping
- Forensic investigation recommendation (full vs. targeted)
- Documented remediation plan

Responsible Teams

- Primary: SOC Lead / L2 Analyst
- Supporting: Threat Intelligence | Incident Commander (for scope decisions)

Common Mistakes

- Proceeding to remediation before completing scope assessment — this is the most common cause of reinfection.
- Relying solely on AV detections — sophisticated malware is designed to evade AV. Always supplement with behavioral analysis.
- Not capturing memory before rebooting or isolating systems — fileless malware leaves no disk artifacts.

Metrics / KPIs

KPI	Measurement	Target
Analysis Completion Time	Time from L2 assignment to remediation plan	< 4 hours (High), < 1 hour (Critical)
Scope Accuracy	Systems identified in analysis vs. actual compromise	> 95%
MITRE Coverage	Techniques mapped per incident	100% of observed TTPs

PHASE 4 — REMEDIATION: CONTAINMENT, ERADICATION & RECOVERY

Purpose

The Remediation phase encompasses three sequential sub-phases — Containment, Eradication, and Recovery — that together achieve the operational objective of removing the threat from the environment and restoring normal business operations while minimizing data loss and business disruption.

Sub-Phase 4A — Containment

OBJECTIVES

- Prevent malware from spreading to additional systems.
- Preserve forensic evidence before it is overwritten or destroyed.
- Block attacker C2 communications to terminate active malware operations.

SHORT-TERM CONTAINMENT ACTIONS

- Isolate infected hosts from the network via VLAN quarantine policy on the firewall — do NOT simply disconnect the network cable, as this may destroy forensic evidence (DHCP lease, ARP cache).
- Disable the affected user account in Active Directory to prevent credential reuse.
- Block identified malicious IPs and domains at the firewall perimeter and DNS layer.
- Capture volatile memory (RAM dump) using WinPmem or DumpIt BEFORE any shutdown or reboot.

> ⚠ **WARNING** — *CRITICAL: RAM capture must occur BEFORE network isolation if the malware is fileless. After isolation, the malware may detect network loss and initiate a self-destruct routine that purges memory artifacts.*

LONG-TERM CONTAINMENT ACTIONS

- Apply emergency patches for exploited vulnerabilities where available.
- Implement temporary ACLs to restrict lateral movement paths.
- Increase monitoring sensitivity on all systems that communicated with the infected host.
- Preserve all relevant evidence: memory images, log exports, malware samples — apply chain of custody immediately.

Sub-Phase 4B — Eradication

OBJECTIVES

- Remove all malicious artifacts, persistence mechanisms, and attacker-created accounts from the environment.
- Eliminate all vulnerabilities exploited during the attack to prevent recurrence.

ERADICATION ACTIONS

- Run full AV/EDR scan on the infected host and all systems identified in the scope assessment.
- Remove persistence mechanisms: Registry Run keys (HKLM/HKCU Run, RunOnce), Scheduled Tasks, Malicious Services, WMI Event Subscriptions.
- Use Autoruns (Sysinternals) to identify and remove all startup persistence entries.
- Delete or quarantine all identified malware files — document file paths and hashes before deletion.
- Reset credentials for all accounts that accessed the infected system during the compromise window.
- Remove any attacker-created accounts identified during analysis.
- Apply all relevant security patches before proceeding to Recovery.

> **NOTE**
> *ERADICATION VALIDATION: Before proceeding to Recovery, the Incident Commander must formally sign off that all identified persistence mechanisms have been removed and all IOCs have been validated as cleared.*

Sub-Phase 4C — Recovery

OBJECTIVES

- Safely return affected systems to production operation with confidence that the threat has been fully eradicated.
- Restore data integrity from trusted backups where required.
- Confirm normal business operations with enhanced monitoring.

RECOVERY ACTIONS

- Reimage the infected system from a known-clean baseline image where system integrity cannot be guaranteed — this is the preferred approach for Critical severity incidents.
- Restore data from clean, verified backups — validate backup integrity via hash comparison before restoration.
- Apply all pending security patches before reconnecting the system to the production network.
- Perform full AV/EDR validation scan immediately prior to network reconnection.
- Monitor recovered systems intensively for 72 hours post-recovery using SIEM rules tuned to the specific IOCs and TTPs from this incident.
- Restore business services in priority order — critical systems first, per the Business Continuity Plan.

Responsible Teams

- Containment: SOC Lead / L2 | IT Operations (network isolation)
- Eradication: SOC Lead / L2 | IT Operations (system remediation)
- Recovery: IT Operations (system restoration) | SOC Lead (validation and monitoring)

Common Mistakes

- Reimaging without first completing scope assessment — if additional infected systems are not identified, reinfection will occur within hours.
- Restoring from backups that were taken during the compromise window — always verify the backup timestamp predates the earliest confirmed infection indicator.
- Reconnecting systems before patches are applied — the same vulnerability that enabled initial access will be exploited again.

Metrics / KPIs

KPI	Measurement	Target
Containment Time	Time from confirmation to full network isolation	< 30 min (Critical)
Mean Time to Remediate (MTTR)	Incident open to eradication complete	< 8 hours (High)
Recovery Time Objective (RTO)	System isolation to full restoration	Per BCP/DRP
Reinfection Rate	Incidents reopened due to incomplete eradication	0%

PHASE 5 — POST-INCIDENT ACTIVITIES

Purpose

The Post-Incident phase transforms the operational experience of handling a malware incident into organizational knowledge that strengthens future detection, response, and prevention capabilities. It is the phase most frequently skipped under operational pressure — and the phase that delivers the highest long-term security value.

Objectives

- Produce a final incident report that meets audit, regulatory, and management reporting requirements.
- Conduct a structured Post-Incident Review (PIR) to identify people, process, and technology gaps.
- Update detection rules, playbooks, and procedures based on confirmed findings.
- Fulfill any regulatory or legal reporting obligations within required timeframes.

Key Activities

INCIDENT REPORTING

- Draft the final incident report using the Incident Report Template (Appendix of Playbook) within 72 hours of incident closure.
- The report must include: Executive Summary, Incident Timeline, Root Cause Analysis, Scope and Impact, Containment and Eradication Actions, Recovery Activities, and Recommendations.

- Submit the report to: Incident Commander, SOC Lead, CISO, and relevant business stakeholders.

POST-INCIDENT REVIEW (PIR)

- Schedule PIR meeting within 72 hours of incident closure — include all teams that participated in the response.
- Structure the PIR around: What happened? What worked? What failed? What must change?
- Document all identified gaps and assign corrective action owners with completion deadlines.
- Classify gaps as: People (training), Process (procedure), or Technology (tooling/detection).

DETECTION ENGINEERING UPDATES

- Create or update SIEM detection rules based on IOCs and TTPs confirmed during the investigation.
- Tune existing rules to reduce false positives identified during the incident.
- Update the MITRE ATT&CK coverage heatmap to reflect new detection capabilities.

REGULATORY & LEGAL REPORTING

- Assess whether the incident triggers mandatory breach notification obligations under applicable regulations (GDPR, NCA ECC, PCI-DSS, sector-specific requirements).
- Coordinate external communications through designated management and legal counsel — do NOT issue external communications without approval.
- Retain all incident records in accordance with the organization's record retention policy.

Outputs / Key Deliverables

- Final Incident Report (submitted to stakeholders)
- Root Cause Analysis document
- Lessons Learned Report with corrective action tracker
- Updated SIEM detection rules
- Updated playbook and procedures (if applicable)
- Regulatory notification (if required)

Common Mistakes

- Holding the PIR too late — memories fade and the value of lessons diminishes rapidly. 72 hours is the maximum acceptable delay.
- Focusing only on technology failures — the majority of IR failures are people and process issues.
- Failing to track corrective action completion — lessons learned documents with no owner and no deadline have zero operational value.

Metrics / KPIs

KPI	Measurement	Target
PIR Completion	PIR meetings held within 72 hours of closure	100%
Report Timeliness	Final report submitted within 72 hours	100%
Corrective Action Closure	Actions closed on time / Actions assigned	> 90% within 30 days
Detection Improvement Rate	New/updated rules per incident	> 1 per incident

5. Workflow Explanation

This section provides a complete narrative explanation of the end-to-end incident response workflow for malware infection incidents. The workflow is presented step-by-step with actor assignments, decision points, and expected outcomes at each stage.

5.1 Workflow Overview — ASCII Flow



5.2 Step-by-Step Workflow Narrative

01	Alert Generated	SIEM / EDR	An automated alert fires from the SIEM, EDR platform, anti-malware engine, or is generated by a user reporting suspicious system behavior. The alert is queued in the SOC ticketing system and assigned to the on-duty L1 analyst.
02	Validation	SOC L1	The L1 analyst performs initial validation: checks the alert source against the whitelist, runs the alert's key

			indicators (file hashes, IPs, domains) against threat intelligence feeds, and reviews correlated SIEM events from the affected host. Decision: false positive or genuine indicator.
▼			
03	Ticket Creation	SOC L1	Upon confirming the alert is not a false positive, the L1 analyst creates an incident ticket with all initial findings documented. The ticket establishes the official incident record that will be maintained throughout the response lifecycle.
▼			
04	Decision Tree Navigation	SOC L1	The analyst navigates the 7-question decision tree to determine current severity and required immediate actions. Each question evaluates a specific threat indicator (IOC match, process injection, C2 traffic, persistence, lateral movement, exfiltration).
▼			
05	Escalation to L2	SOC L1 → L2	Based on decision tree outcome, the L1 analyst escalates to L2 with the incident ticket, initial IOCs, SIEM query results, and their severity assessment. Escalation must occur within the SLA defined for the assigned severity level.
▼			
06	Deep Investigation	SOC L2	The L2 analyst conducts comprehensive investigation: sandbox analysis of suspicious files, memory forensics if fileless malware is suspected, full scope assessment of affected systems, attack timeline construction, and MITRE ATT&CK technique mapping.
▼			
07	Containment	SOC L2 + IT Ops	With scope confirmed, containment actions are executed: network isolation via VLAN quarantine, RAM capture, C2 IP/domain blocking at perimeter, affected account disabling. Containment actions are logged with timestamps in the incident ticket.
▼			
08	Eradication	SOC L2 + IT Ops	All malicious artifacts are removed from the environment: malware files deleted, persistence mechanisms eliminated, credentials reset, patches applied. Eradication is validated by the Incident Commander before proceeding.
▼			
09	Recovery	IT Ops + SOC L2	Affected systems are reimaged from clean baseline, data restored from validated backups, systems patched and validated, then reconnected to production. Enhanced SIEM monitoring is applied for 72 hours post-recovery.
▼			

10	Lessons Learned	All Teams	PIR meeting held within 72 hours. Final incident report drafted and distributed. Detection rules updated. Playbook updated if procedure gaps identified. Corrective actions assigned with owners and deadlines.

5.3 Decision Branch — Severity Escalation Triggers

Trigger Condition	Severity	Immediate Action
IOC match only, no active behavior	Medium	L2 investigation, < 4 hour SLA
IOC match + persistence mechanisms	High	L2/L3 involvement, < 1 hour SLA
IOC match + confirmed C2 traffic	Critical	Immediate isolation, L3 notified
Lateral movement detected	Critical	Network segment isolation, L3 + Mgmt
Data exfiltration confirmed	Critical	Evidence preservation, CISO + Legal
Ransomware dropper identified	Critical	War room activation, C-suite notification

6. Decision Tree Documentation

The Decision Tree is one of the most operationally critical components of this playbook. This section explains the design rationale, each decision point in detail, expected analyst actions, and the escalation logic embedded within the tree structure.

6.1 Why a Decision Tree

During an active malware incident, analysts face significant cognitive pressure: multiple alerts firing simultaneously, management requesting updates, containment actions requiring authorization, and forensic evidence potentially being overwritten. In this environment, unstructured investigation leads to:

- Inconsistent severity classifications between analysts on the same team.
- Missed escalation triggers due to incomplete alert review.
- Delayed containment while analysts seek guidance on next steps.
- Audit failures due to inability to demonstrate a structured triage process.

The decision tree addresses all of these risks by providing a pre-defined, peer-reviewed branching logic that guides the analyst from alert receipt to action determination in a consistent, repeatable, and auditable manner.

6.2 Decision Tree — Annotated Reference

Q#	Question	Analyst Guidance	YES → Action	NO → Action
Q1	**Whitelisted source?**	Check the alert source IP, hostname, and process against the approved whitelist maintained in the SIEM. If whitelisted, the alert is almost certainly a false positive — but still document the reason.	Close as False Positive. Document in ticket with whitelist match evidence.	Proceed to Q2. The alert source is not pre-approved.
Q2	**IOC match in Threat Intel?**	Query file hashes (MD5/SHA256), IP addresses, and domains from the alert against: VirusTotal, AlienVault OTX, and internal threat intel repository. A match confirms known-malicious indicators.	Open High severity ticket. Escalate to L2 immediately.	Proceed to Q3. No known-bad match, but investigation continues.
Q3	**Process injection or abnormal parent-child?**	Review process tree in EDR or SIEM (Sysmon Event 8 — CreateRemoteThread). Look for: Office apps spawning cmd.exe/PowerShell, svchost.exe from non-standard paths, lsass.exe with child processes.	Confirm infection. Isolate host immediately via firewall VLAN quarantine.	Proceed to Q4. No injection evidence yet.
Q4	**Outbound traffic to suspicious IPs/domains?**	Review outbound network connections from the affected host. Look for: connections to non-categorized domains, beaconing patterns (regular interval connections), connections to IPs flagged in threat intel feeds.	Confirm C2 activity. Block at firewall. Escalate to Critical severity.	Proceed to Q5. No confirmed C2 observed.

Q5	**Persistence mechanisms present?**	Use Autoruns or Sysmon logs (Event 13 — registry, Event 1 — schtasks) to check: HKLM/HKCU Run keys, Scheduled Tasks, New Windows Services (Event ID 7045), WMI Event Subscriptions.	Confirmed persistent infection. Begin Eradication phase immediately.	Proceed to Q6. No persistence identified yet.
Q6	**Lateral movement evidence?**	Query SIEM for authentication events FROM the compromised host TO other systems. Look for: SMB connections, RDP sessions, Pass-the-Hash indicators (4624 Type 3 with NTLM from compromised host).	Escalate to Critical. Isolate the network segment. Notify L3.	Assign Medium severity. Continue deep investigation.
Q7	**Data exfiltration evidence?**	Review outbound data transfer volumes from the affected host. Look for: large uploads to cloud storage, DNS tunneling indicators (high-volume DNS with long query strings), staged data in %TEMP% or unusual directories.	Escalate to Critical. Preserve all evidence. Notify CISO + Legal immediately.	Proceed with standard Eradication + Recovery workflow.

6.3 Decision Tree — Worked Example

📋 NOTE	*SCENARIO: SIEM fires a 'Malware Detected' alert on DESKTOP-HR04 at 08:47 AM. The analyst applies the decision tree.*

- Q1: Alert source is DESKTOP-HR04 — not on whitelist. → Proceed to Q2.
- Q2: File hash lookup on VirusTotal returns 47/72 detections for Emotet. → Escalate to L2, open High ticket.
- Q3: Sysmon logs show EXCEL.EXE spawning POWERSHELL.EXE with encoded parameters. → Confirm infection. Isolate host.
- Q4: SIEM query shows outbound HTTP beaconing to 185.220.x.x (TI feed: known Emotet C2). → Confirm C2. Block at firewall. Escalate to Critical.
- Q5: Autoruns shows new Run key: HKCU\Software\Microsoft\Windows\CurrentVersion\Run → Emotet_update.exe. → Begin Eradication.
- Q6: SIEM shows SMB connection from DESKTOP-HR04 to FILE-SERVER01 with invalid credentials. → Isolate network segment. Notify L3.
- Q7: No evidence of large outbound transfers in the review window. → Proceed with standard Eradication + Recovery.

RESULT: Incident classified Critical. Containment, eradication, and recovery completed within 8 hours. Scope limited to two systems.

7. MITRE ATT&CK Documentation

This section explains how the MITRE ATT&CK framework is integrated into this playbook, how analysts should apply the technique mappings during investigation, and how the coverage heatmap informs detection engineering priorities.

7.1 Why MITRE ATT&CK is Integrated

- MITRE ATT&CK provides a globally recognized, empirically grounded taxonomy of adversary behaviors derived from real-world threat intelligence. Its integration into this playbook delivers four operational benefits:
- Common Language: ATT&CK technique IDs (e.g., T1059.001) provide a universal identifier for adversary behaviors that transcends tool-specific terminology, enabling consistent communication across SOC tiers, threat intelligence, and external partners.
- Detection Alignment: Mapping observed behaviors to ATT&CK techniques allows analysts to validate that SIEM detection rules cover the relevant adversary actions — not just specific malware signatures that may be evaded.
- Gap Identification: The coverage heatmap (Playbook Section 7) makes detection gaps immediately visible, enabling SIEM engineers to prioritize rule development for high-risk, low-coverage techniques.
- Threat Intelligence Contextualization: ATT&CK technique mappings link incident observations to known threat actor profiles, enabling teams to anticipate attacker next steps based on campaign intelligence.

7.2 How to Use the MITRE Mapping During Investigation

Step	Action	How to Apply
1	**Observe Behavior**	Document the specific behavior observed: e.g., 'PowerShell executed with encoded parameters spawned by WINWORD.EXE'.
2	**Map to Tactic**	Identify which ATT&CK tactic the behavior represents: Execution / Persistence / Defense Evasion / C2 / Exfiltration etc.
3	**Identify Technique**	Locate the specific technique ID using the ATT&CK Navigator or attack.mitre.org. Example: PowerShell = T1059.001.
4	**Review Sub-techniques**	Check if a more specific sub-technique applies. T1059 (Command & Scripting Interpreter) has multiple sub-techniques for different interpreters.
5	**Check Detection Guidance**	The ATT&CK technique page provides data sources and detection recommendations — use these to refine SIEM queries.
6	**Document in Ticket**	Record all confirmed technique IDs in the incident ticket. This data feeds post-incident detection engineering.
7	**Update Heatmap**	After incident closure, update the team's ATT&CK coverage heatmap to reflect new detection capabilities developed during the incident.

7.3 Technique Quick-Reference — Mapped to This Playbook

Technique ID	Name	Tactic	Key Detection Signal
T1566.001	**Spearphishing Attachment**	Initial Access	Email gateway: Office spawning cmd.exe/powershell.exe
T1189	**Drive-by Compromise**	Initial Access	Browser child processes, new files in %TEMP%
T1078	**Valid Accounts**	Initial Access	Logins from unusual geo/time, auth failures then success
T1059.001	**PowerShell**	Execution	Encoded commands, ScriptBlock logging, execution policy bypass
T1059.003	**Windows Command Shell**	Execution	cmd.exe spawned by Office/Browser
T1047	**WMI**	Execution	New EventFilter/EventConsumer subscriptions
T1204.002	**Malicious File**	Execution	New process from Downloads/Temp
T1547.001	**Registry Run Keys**	Persistence	Sysmon Event 13, new Run key from non-standard paths
T1053.005	**Scheduled Task**	Persistence	Sysmon Event 1 (schtasks.exe), Event ID 4698
T1543.003	**Windows Service**	Persistence	Event ID 7045, service from unusual path
T1036	**Masquerading**	Defense Evasion	Process from non-standard path, parent-child anomalies
T1027	**Obfuscated Files**	Defense Evasion	High entropy file writes, encoded PowerShell
T1562.001	**Disable Security Tools**	Defense Evasion	Event ID 1102 (log cleared), service stopped
T1055	**Process Injection**	Defense Evasion	Sysmon Event 8 (CreateRemoteThread)
T1071.001	**HTTP C2**	C2	Beaconing patterns, HTTP to non-categorized domains
T1071.004	**DNS Tunneling**	C2	High-volume DNS, unusually long query strings
T1573	**Encrypted Channel**	C2	Self-signed certificate anomalies, unexpected encrypted patterns

7.4 Coverage Heatmap — Gap Prioritization

⚠ **WARNING**

PRIORITY GAPS: T1573 (Encrypted C2) and T1189 (Drive-by Compromise) show LOW EDR coverage. These gaps represent significant blind spots that attackers actively exploit. Prioritize detection rule development for these techniques in the next SIEM tuning cycle.

7.5 Limitations of MITRE ATT&CK Integration

- ATT&CK is a knowledge base, not a complete threat model. Not all possible adversary behaviors are documented.
- Technique coverage varies by platform — enterprise Windows techniques are more comprehensively documented than Linux/macOS/Cloud variants.
- ATT&CK mappings should be treated as investigative starting points, not definitive classifications. Novel malware may combine techniques in undocumented ways.
- The framework is updated periodically — version awareness is important. This playbook references ATT&CK v14.

TIP

ANALYST TIP: When a behavior does not map cleanly to a known ATT&CK technique, document it as 'Unclassified — Novel TTP' and submit to the threat intelligence team for analysis. Novel behaviors are high-value intelligence.

8. IOC Collection Documentation

Effective IOC collection is the forensic backbone of malware incident response. This section provides comprehensive guidance on collecting, validating, storing, and maintaining the chain of custody for all Indicators of Compromise identified during an incident.

8.1 Why IOC Collection Matters

- Legal Admissibility: Properly collected and documented IOCs, with chain of custody maintained, can support legal proceedings against threat actors.
- Scope Determination: IOCs enable analysts to identify all affected systems — a single missed system is a vector for reinfection.
- Detection Tuning: IOCs collected during incidents feed directly into SIEM rules, threat intelligence platforms, and firewall blocklists.
- Threat Intelligence Sharing: Sanitized IOCs shared with ISACs and industry partners protect other organizations from the same threat actors.

8.2 IOC Categories — Detailed Reference

8.2.1 File-Based IOCs

WHY IT MATTERS: File-based IOCs are the most direct evidence of malware presence. File hashes are deterministic — the same file always produces the same hash regardless of filename, enabling identification even when malware renames itself.

IOC Type	Examples	Collection Method
MD5/SHA256 Hashes	d41d8cd98f00b204e9800998ecf8427e	PowerShell: Get-FileHash -Path <file> -Algorithm SHA256
File Names & Paths	emotet_update.exe in %APPDATA%	EDR process tree, Sysmon Event 1, Autoruns
File Sizes	Unusual size for named process	Task Manager, Process Explorer (Sysinternals)
Digital Signatures	Unsigned or invalid certificate	Sigcheck (Sysinternals): sigcheck -a -e <path>
File Creation Time	Files created at 08:12 AM on infection day	FTK Imager, Sysmon Event 11 (FileCreate)

8.2.2 Network-Based IOCs

WHY IT MATTERS: Network IOCs reveal C2 infrastructure, data exfiltration channels, and lateral movement paths. They can also be actioned immediately — blocking a C2 IP at the firewall severs the attacker's active connection.

IOC Type	Examples	Collection Method
IP Addresses	185.220.x.x (Tor exit node)	SIEM netflow, Wireshark, firewall logs
Domains	update-service[.]ru	DNS query logs, Zeek/Bro connection logs
URLs	http://malicious[.]ru/payload.exe	Proxy logs, web gateway logs, Wireshark

Ports	TCP 4444 (common RAT C2)	Firewall logs, netstat, TCPView (Sysinternals)
SSL/TLS Certificates	Self-signed cert, unusual CN	JA3 fingerprinting, SSL inspection logs
Beaconing Intervals	Outbound connection every 300 seconds	SIEM time-series analysis

8.2.3 Host-Based IOCs

WHY IT MATTERS: Host-based IOCs reveal how the malware established persistence and what access it maintained — critical for ensuring complete eradication.

IOC Type	Examples	Collection Method
Registry Keys	HKCU\Run\emotet_update	Sysmon Event 13, RegShot, Autoruns
Scheduled Tasks	Task: MicrosoftEdgeUpdate (fake)	Sysmon Event 1 (schtasks), Task Scheduler
Windows Services	Service: svchost32 from C:\Users\	Event ID 7045, sc query, Autoruns
Mutex Names	Global\M-{GUID} (Emotet mutex)	Process Explorer (Sysinternals)
WMI Subscriptions	EventFilter/Consumer/Binding triplets	Get-WMIObject, Sysmon WMI events
Prefetch Files	POWERSHELL.EXE-XXXXX.pf	FTK Imager, PECmd (Eric Zimmermann tools)

8.2.4 Memory-Based IOCs

WHY IT MATTERS: Fileless malware exists ONLY in memory — without RAM analysis, it leaves no evidence and cannot be identified by traditional AV or disk-based forensic tools.

IOC Type	Examples	Collection Method
Injected Code	shellcode in explorer.exe	Volatility 3: windows.malfind
Suspicious DLLs	Unsigned DLL in lsass.exe	Volatility 3: windows.dlllist
Network Sockets	Active connection in terminated process	Volatility 3: windows.netstat
Process Hollowing	svchost.exe with unusual base address	Volatility 3: windows.pslist + malfind
Credentials in Memory	NTLM hashes in lsass.exe	Volatility 3: windows.hashdump (authorized use only)

⚠ **WARNING**

RAM CAPTURE ORDER OF OPERATIONS: 1) Capture RAM BEFORE isolation. 2) Hash the RAM dump immediately after capture (SHA256). 3) Document: capture tool, version, analyst name, timestamp, hash value. 4) Copy to secure evidence storage. 5) DO NOT reboot the system before RAM capture is complete.

8.2.5 Log-Based IOCs

WHY IT MATTERS: Windows Event Logs and Sysmon logs provide a chronological record of attacker actions that survives across reboots — they are the most reliable source of incident timeline reconstruction.

Event ID	Meaning	Investigation Value
4688	**Process Creation (with command line if audited)**	Reveals full command line of malware execution
4624/4625	**Successful / Failed Logon**	Identifies credential-based lateral movement
7045	**New Service Installed**	Malware service persistence detection
1102	**Security Log Cleared**	Attacker covering tracks — high confidence indicator
4698	**Scheduled Task Created**	Malware scheduled task persistence
Sysmon 1	**Process Create (with full details)**	Most valuable process creation log source
Sysmon 3	**Network Connection**	Process-to-IP/domain correlation
Sysmon 8	**CreateRemoteThread**	Process injection detection
Sysmon 11	**File Create**	Malware file drop detection
Sysmon 13	**Registry Set Value**	Persistence mechanism via registry

8.3 Chain of Custody

NOTE	*Chain of custody documentation is mandatory for ALL evidence collected during malware incidents. Without it, evidence cannot be used in legal proceedings and may indicate negligent incident handling during audits.*

For every piece of evidence collected, record the following immediately:

Field	Requirement
Evidence Item Description	Specific description: e.g., 'RAM dump of DESKTOP-HR04 captured using WinPmem v3.3'
Collecting Analyst	Full name and role
Date and Time of Collection	UTC timestamp — NEVER local time
Collection Method/Tool	Tool name and version used
SHA256 Hash of Evidence	Computed immediately after collection — used to verify integrity
Storage Location	Secure network share path or physical media location
Access Log	Every person who accesses the evidence must be logged with timestamp
Transfer Records	If evidence is transferred, document: from/to, method, date, both parties

8.4 Common IOC Collection Mistakes

> ⚠ **WARNING**
>
> *MISTAKE: Rebooting or shutting down a system before capturing RAM. Once power is removed, all memory-resident malware artifacts are destroyed permanently and cannot be recovered.*

- Running hash computations on live, active files — the hash will change if the file is in use. Always compute hashes on copies or offline.
- Using inconsistent timestamps — always document in UTC. Local time zones cause confusion in multi-region incidents.
- Storing evidence on the infected system — evidence must be immediately transferred to isolated, write-protected storage.
- Failing to document collection tool versions — if tool output is questioned in legal proceedings, version information is required for validation.

9. Escalation Documentation

Escalation is the process by which incident severity and ownership is elevated to ensure that the appropriate expertise, authority, and resources are applied at the right time. This section documents escalation criteria, communication protocols, and management notification requirements.

9.1 Escalation Principles

- Escalate Early, Escalate Often: It is better to escalate a medium-severity incident that turns out to be low than to fail to escalate a critical incident promptly. The cost of an unnecessary escalation is a brief conversation. The cost of a missed escalation can be catastrophic.
- Escalation is Not Failure: Escalating an incident is a sign of good judgment, not an indication of analyst inadequacy. SOC culture must reinforce this principle.
- Document Every Escalation: Every escalation action must be recorded in the incident ticket with timestamp, escalation target, method, and reason.

9.2 Escalation Criteria Matrix

Trigger Condition	Escalate To	Method	Timeframe	Severity
Active C2 confirmed	**Incident Commander (L3)**	Phone + Ticket	Immediately	**Critical**
Malware spreading to multiple hosts	**SOC Lead + L3**	Phone + Ticket	< 15 minutes	**Critical**
Data exfiltration confirmed	**L3 + CISO + Legal**	Phone + Email	Immediately	**Critical**
Critical server infected	**L2 + IT Manager**	Phone + Ticket	< 30 minutes	**High**
Ransomware dropper identified	**L3 + Management**	Phone + War Room	Immediately	**Critical**
Incident unresolved > 4 hours	**L3 + CISO**	Status Meeting	< 4 hours	**Any**
Confirmed IOC match, no active behavior	**SOC Lead (L2)**	Ticket	< 30 minutes	**High**
Privileged account compromised	**L3 + IT Manager**	Phone + Ticket	Immediately	**Critical**

9.3 Communication Protocols

9.3.1 Internal Communication Standards

- All incident communications must reference the Incident ID (format: IR-YYYY-XXX) to enable correlation across teams.
- Phone escalation must be followed by a ticket update within 5 minutes — verbal-only communications are not auditable.
- Use established incident communication channels (dedicated Slack/Teams channel, not personal messaging) to maintain a searchable record.

- Status updates must be provided to the Incident Commander every 30 minutes during Critical incidents and every hour during High incidents.

9.3.2 Management Notification

- Critical incidents: CISO must be notified within 15 minutes of Critical severity declaration.
- Provide a concise verbal briefing using the SBAR format: Situation / Background / Assessment / Recommendation.
- Follow-up with a written status update within 30 minutes of verbal notification.
- Do not speculate on scope or impact in management briefings — state only what is confirmed.

9.3.3 Legal and Regulatory Notification

⚠ WARNING	*Legal counsel must be consulted BEFORE any external disclosure, including law enforcement notification, customer notification, or regulatory reporting. Unauthorized external communications can compromise legal privilege and create regulatory violations.*

- Data exfiltration incidents may trigger mandatory breach notification obligations under applicable regulations.
- Regulatory notification timelines (indicative — validate against applicable regulations):

GDPR: 72 hours from awareness of breach to Data Protection Authority notification.
NCA ECC (Egypt): Report to the National Cybersecurity Authority per sector-specific requirements.
PCI-DSS: Notify payment brands and acquiring bank within 24 hours of suspected breach.

10. Tools Documentation

This section provides comprehensive documentation for every tool referenced in the playbook, including purpose, optimal use cases, operational limitations, and best practices. Analysts should reference this section when selecting tools during incident response.

10.1 Primary SIEM Platform

SIEM Platform (e.g., FortiSIEM 7.2)

Phase(s)	All Phases — Central platform for all phases
Purpose	Enterprise SIEM providing centralized log aggregation, event correlation, alert generation, and investigation query capability across all monitored systems and network segments.
When to Use	Use as the primary investigation platform from alert receipt through post-incident rule updates. All SIEM queries during investigation must be documented in the incident ticket.
Advantages	Provides correlated view across all log sources; enables complex multi-source queries; central dashboard for SOC monitoring; supports compliance reporting
Limitations	Query performance degrades with very large result sets — use time-bounded queries; alert fatigue risk if rules not properly tuned; requires ongoing rule maintenance
Alternatives	Splunk Enterprise Security | IBM QRadar | Microsoft Sentinel | Elastic SIEM
Best Practice	Always time-bound SIEM queries to the investigation window + 24-hour buffer. Export query results to the evidence repository immediately — SIEM data may be purged after retention period.

10.2 Network Security

Next-Generation Firewall (e.g., FortiGate)

Phase(s)	Containment — Network isolation and blocking
Purpose	Network perimeter control enabling VLAN-based host quarantine, IP/domain blocking, IPS signature enforcement, and application control for malware C2 communications.
When to Use	Use for immediate host isolation (VLAN quarantine), blocking confirmed malicious IPs and domains, and enforcing network ACLs to restrict lateral movement.
Advantages	Real-time blocking capability; VLAN quarantine does not require physical access to the affected host; IPS provides additional detection layer
Limitations	Encrypted C2 traffic (T1573) may bypass URL-based blocking — certificate inspection required; VLAN quarantine requires pre-configured quarantine VLAN
Alternatives	Cisco ASA/Firepower | Palo Alto NGFW | Check Point
Best Practice	Ensure quarantine VLAN is pre-configured and tested before an incident occurs. Blocking C2 IPs must be documented in the incident ticket with timestamp.

10.3 Forensic Tools

Sysinternals Suite

Phase(s)	Identification | Eradication
Purpose	Collection of advanced Windows system utilities for process analysis, network connection review, autoruns inspection, and real-time system monitoring.
When to Use	Use Process Explorer to view full process trees and DLL loads; Autoruns to identify all persistence mechanisms; TCPView for real-time network connections; ProcMon for real-time file/registry/process activity.
Advantages	Free; provided by Microsoft; extremely powerful for live system analysis; trusted by DFIR community globally
Limitations	Windows-only; some tools require admin rights; ProcMon can generate very large log files quickly
Alternatives	Process Hacker (open source) | Velociraptor (enterprise)
Best Practice	Download Sysinternals directly from Microsoft (live.sysinternals.com) to ensure you have the latest version. Do not use tools from unverified sources on evidence systems.

Volatility 3

Phase(s)	Identification — Memory forensics
Purpose	Open-source memory forensics framework for analyzing RAM dumps from Windows, Linux, and macOS systems to extract running processes, network connections, loaded DLLs, and injected code.
When to Use	Use when fileless malware is suspected, when a process behaves suspiciously but no disk artifacts are found, or when you need to validate whether malware is actively running in memory.
Advantages	Open source; Python-based (cross-platform); extensive plugin library for Windows forensics; industry standard for memory analysis
Limitations	Requires Python environment setup; some plugins require symbol files; large RAM dumps require significant analysis time
Alternatives	Rekall (deprecated but functional) | WinPmem (acquisition only)
Best Practice	Key Volatility commands: windows.pslist (processes), windows.netstat (connections), windows.malfind (injected code), windows.dlllist (loaded DLLs). Always validate RAM dump integrity with SHA256 hash before analysis.

FTK Imager

Phase(s)	Identification — Evidence acquisition
Purpose	Forensic imaging tool for acquiring exact bit-for-bit copies of disk drives and memory, generating hash verification values, and previewing evidence without writing to the source.

When to Use	Use for disk imaging when full forensic acquisition is required, for RAM capture as an alternative to WinPmem, and for previewing files and directories on suspect media.
Advantages	Industry-standard forensic tool; generates MD5 and SHA1 hashes automatically; write-blocker compatible; free version available
Limitations	Large disk images take significant time; requires forensic workstation with adequate storage; Windows-centric
Alternatives	dd (Linux) | Guymager | Magnet Acquire
Best Practice	Always verify hash values after acquisition. Store images on forensic-grade write-protected media. Never mount images on the original suspect system.

10.4 Threat Intelligence Platforms

VirusTotal / Any.run

Phase(s)	Identification — Malware analysis
Purpose	Cloud-based malware analysis platforms: VirusTotal for multi-AV hash scanning and file/URL analysis; Any.run for interactive sandbox analysis of malware behavior in a real Windows environment.
When to Use	Submit suspicious file hashes (not the files themselves unless authorized) to VirusTotal for rapid multi-engine scanning. Use Any.run for behavioral analysis of confirmed malware samples in an isolated environment.
Advantages	Fast results; free tier available; VirusTotal aggregates 70+ AV engines; Any.run provides interactive analysis with network traffic capture
Limitations	CRITICAL: Submitting live malware files to public VirusTotal shares them with the security community — do not submit files containing sensitive data. Any.run requires internet access from the analyst workstation.
Alternatives	Hybrid Analysis | Joe Sandbox | Cuckoo Sandbox (on-premise)
Best Practice	Always submit SHA256 hashes first rather than files. Only submit files to sandboxes after confirming no sensitive data is embedded. Document analysis results with screenshots in the incident ticket.

Sysmon (System Monitor)

Phase(s)	Identification — Enhanced logging
Purpose	Windows system service and driver that enhances Windows Event Log telemetry with detailed process creation, network connection, registry modification, and file creation events.
When to Use	Sysmon should be deployed in Preparation phase and remains active throughout all incidents. During investigation, Sysmon logs are the primary source for process tree reconstruction and behavior timeline.
Advantages	Free; dramatically enhances Windows logging quality; provides unique identifiers for event correlation; integrates directly with SIEM

Limitations	Requires configuration tuning — default configuration generates excessive noise; configuration updates require rolling deployment; does not collect kernel-level events
Alternatives	Windows Event Auditing (less detailed) | EDR agent logging
Best Practice	Use the SwiftOnSecurity Sysmon configuration as the baseline. Review and update the configuration after every major incident to capture newly identified attacker behaviors.

MITRE ATT&CK Navigator

Phase(s)	All Phases — Framework visualization
Purpose	Web-based tool for visualizing MITRE ATT&CK technique coverage, annotating technique heatmaps, and tracking detection coverage gaps across the ATT&CK matrix.
When to Use	Use during analysis to map confirmed techniques and identify likely next-stage attacker behaviors. Use during post-incident review to update detection coverage maps and prioritize SIEM rule development.
Advantages	Free; web-based (no installation); exports to SVG/JSON; enables team-wide visibility of detection coverage
Limitations	Requires manual update — does not auto-import from SIEM or EDR; web-based version requires internet access
Alternatives	Vectra AI Cognito | Trellix ATT&CK Navigator integrations
Best Practice	Maintain a persistent ATT&CK layer file for your SOC that is updated after every incident. Include coverage assessments (High/Medium/Low) for each technique to prioritize detection investment.

11. Roles Documentation

This section provides detailed role definitions for all personnel involved in malware incident response, including a RACI matrix that clarifies Responsibility, Accountability, Consultation, and Information requirements for each key activity.

11.1 RACI Legend

Code	Meaning
R	Responsible — Performs the activity
A	Accountable — Final authority; ensures activity is completed correctly
C	Consulted — Provides input and expertise
I	Informed — Notified of activity or outcome
-	Not involved in this activity

11.2 RACI Matrix — Malware Incident Response

Activity	L1	L2	L3/IC	IT Ops	TI	Legal	CISO
Receive and acknowledge alert	R	I	I	-	-	-	-
Validate alert / false positive check	R	C	I	-	-	-	-
Create incident ticket	R	A	I	-	-	-	-
Apply decision tree	R	C	I	-	-	-	-
Escalate to L2	R	A	I	-	-	-	-
Deep malware investigation	C	R	A	-	C	-	-
MITRE ATT&CK mapping	I	R	C	-	C	-	-
Sandbox malware analysis	I	R	A	-	C	-	-
Authorize host isolation	I	R	A	-	-	-	I
Execute network isolation	-	C	A	R	-	-	-
Block C2 at firewall	-	R	A	C	-	-	-
RAM dump acquisition	-	R	A	C	-	-	-
Malware removal and eradication	-	C	A	R	-	-	-
System reimaging	-	C	A	R	-	-	-
Credential reset	-	R	A	C	-	-	-
Notify CISO	-	I	R	-	-	-	A

Notify Legal (data breach)	-	I	R	-	-	A	-
Final incident report	-	R	A	-	-	-	I
Post-Incident Review facilitation	-	R	A	-	C	-	I
Update detection rules	-	R	C	-	C	-	-

11.3 Role Profiles

SOC Analyst — Level 1 (L1)

- First responder for all SIEM alerts during assigned shift. Primary responsibility is accurate, timely triage.
- Must complete playbook decision tree for every malware alert — no exceptions.
- Must create an incident ticket BEFORE beginning investigation — the ticket is the official record.
- Must escalate within defined SLAs — hesitation in escalating is the most common L1 failure mode.
- NOT authorized to execute containment actions independently — must be directed by L2/L3.

TIP *L1 PERFORMANCE STANDARD: The primary measure of L1 effectiveness is not investigation depth — it is triage speed and escalation accuracy. A fast, accurate triage with a clean handover to L2 is excellent L1 performance.*

SOC Lead / L2 Analyst

- Deep technical investigation authority — responsible for all malware identification, sandbox analysis, and scope assessment.
- Authorized to direct L1 actions, request IT operations support, and approve short-term containment actions.
- Responsible for maintaining the incident timeline and ensuring the ticket reflects all investigation findings in near-real-time.
- Must formally brief L3/Incident Commander upon taking ownership of a High or Critical incident.
- Responsible for MITRE ATT&CK mapping and detection rule update recommendations post-incident.

Incident Commander / L3

- Ultimate authority over all incident response decisions from containment through recovery.
- Authorizes all major containment actions (network isolation, account disabling) and recovery actions (system reconnection).
- Management communication focal point — provides executive briefings and coordinates with CISO.
- Chairs the Post-Incident Review and is accountable for ensuring corrective actions are assigned and tracked.

WARNING *INCIDENT COMMANDER PRINCIPLE: The IC does not investigate — they oversee, authorize, and communicate. An IC who is drawn into technical investigation loses situational awareness and creates a leadership vacuum.*

IT Operations / Sysadmin Team

- Executes physical and logical containment actions directed by L2/L3: network VLAN changes, account management, patch deployment.
- Performs system reimaging using approved baseline images and restores data from verified backups.
- Responsible for maintaining system rebuild documentation and recovery time reporting.

Threat Intelligence Team

- Provides malware family identification, IOC enrichment, and TTP contextualization from internal and external threat intelligence sources.
- Maintains the IOC repository and ensures threat intelligence feeds are current and actionable.
- Develops detection content (SIEM rules, YARA signatures) based on confirmed incident IOCs.

CISO / Management

- Receives Critical incident notifications within 15 minutes of severity declaration.
- Makes business continuity decisions (e.g., taking systems offline that cannot be quickly isolated).
- Approves external communications and coordinates with Legal and PR as required.
- Reviews and approves the final incident report and corrective action plan.

12. Operational Guidelines

This section documents the operational standards that govern analyst behavior, communication, evidence handling, and documentation throughout the incident response lifecycle.

12.1 Communication Rules

- All incident communications must use the assigned Incident ID as the subject/reference prefix.
- Do NOT use personal email or messaging applications for incident communications — use designated incident channels only.
- Avoid speculative language in communications: state only confirmed facts. Use 'suspected' or 'possible' for unconfirmed observations.
- Phone escalations must be followed by a ticket update within 5 minutes.
- All outbound external communications (to customers, press, law enforcement) require explicit CISO approval.

12.2 Evidence Handling Standards

⚠ WARNING	*EVIDENCE CONTAMINATION: Any unauthorized access to, modification of, or deletion of evidence during an incident investigation constitutes evidence contamination and may have legal consequences. Follow these standards rigorously.*

- Evidence must be collected before containment actions whenever operationally possible — isolation destroys volatile evidence.
- All collected evidence must be immediately hashed (SHA256) and documented with chain of custody information.
- Evidence must be stored on isolated, write-protected forensic storage — never on the analyst's local workstation.
- Only authorized forensic analysts may access collected evidence — access must be logged.
- Evidence retention: maintain all incident evidence for a minimum of 24 months, or per applicable regulatory requirements (whichever is longer).

12.3 Documentation Standards

- All investigation actions must be documented in the incident ticket within 15 minutes of completion — real-time documentation is required.
- Document WHAT you did, WHEN you did it (UTC timestamp), WHY you did it, and WHAT you found.
- Never delete or modify ticket entries — if a finding is later disproven, add a new entry noting the correction.
- Screenshots must be annotated with: timestamp, analyst name, and what the screenshot demonstrates.

12.4 Log Retention

Log Type	Retention Period	Storage Requirement

SIEM Raw Logs	12 months minimum	Encrypted, tamper-evident storage
Incident Tickets	36 months	Ticketing system with backup
Forensic Evidence (RAM/Disk)	24 months minimum	Write-protected forensic storage, hashed
Incident Reports	36 months	Secure document management system
Chain of Custody Records	Lifetime of evidence + 12 months	Secure, access-controlled storage
Post-Incident Review Records	36 months	Document management system

13. Key Performance Indicators (KPIs)

This section defines the KPIs used to measure SOC effectiveness in malware incident response. KPIs must be reviewed monthly by SOC leadership and reported quarterly to CISO.

13.1 Detection KPIs

KPI	Formula	Target	Frequency	Owner
Mean Time to Detect (MTTD)	Σ(Detection Time - Infection Time) / N Incidents	< 30 minutes	Monthly	SOC Lead
Alert-to-Ticket Time	Ticket creation time - Alert receipt time	< 10 minutes	Monthly	SOC Lead
False Positive Rate	FP Closures / Total Alerts × 100	< 20%	Monthly	SOC Lead
Detection Rule Coverage	Covered ATT&CK Techniques / Total Mapped Techniques	> 80%	Quarterly	TI Team
Alert Volume Trend	Month-over-month alert count change	Monitored	Monthly	SOC Lead

13.2 Response KPIs

KPI	Formula	Target	Frequency	Owner
Mean Time to Respond (MTTR)	Σ(Incident Closure - Incident Open) / N	< 8 hours (High)	Monthly	IC / SOC Lead
Containment Time	Confirmation to full isolation time	< 30 min (Critical)	Per Incident	SOC Lead
Escalation Accuracy	Correct escalations / Total escalations	> 90%	Monthly	SOC Lead
SLA Compliance Rate	Incidents within SLA / Total incidents	> 95%	Monthly	SOC Lead
Reinfection Rate	Reopened incidents / Closed incidents	0%	Monthly	SOC Lead

13.3 Post-Incident KPIs

KPI	Formula	Target	Frequency	Owner
PIR Completion Rate	PIRs held within 72h / Total incidents	100%	Monthly	IC
Report Timeliness	Reports submitted within 72h / Total	100%	Monthly	SOC Lead

Corrective Action Closure	Closed actions / Assigned actions	> 90% within 30 days	Monthly	IC
Rules Updated Per Incident	New/updated SIEM rules per incident	≥ 1 per incident	Monthly	TI Team
Training Completion	Analysts completing quarterly exercises	100%	Quarterly	SOC Lead

14. Risks and Limitations

No incident response playbook can anticipate every possible attack scenario or compensate for every organizational gap. This section documents the known scope, dependencies, limitations, and risks associated with this playbook.

14.1 What This Playbook Covers

- Malware infection incidents on Windows endpoints within SIEM-monitored environments.
- Malware categories: Trojans, Worms, RATs, Spyware, Ransomware Droppers, Fileless Malware, Rootkits, Backdoors.
- Detection, triage, investigation, containment, eradication, and recovery phases.
- MITRE ATT&CK v14 technique mapping for Initial Access, Execution, Persistence, Defense Evasion, and C2 tactics.

14.2 What This Playbook Does NOT Cover

> ⚠ **WARNING** *If an incident falls outside the scope below, escalate to the Incident Commander immediately. Do not attempt to apply this playbook to out-of-scope incident types.*

- Full ransomware encryption events — a separate Ransomware Playbook is required.
- Mobile device malware (Android/iOS) — requires Mobile Security Playbook.
- Cloud workload infections (AWS EC2, Azure VM, GCP) — requires Cloud IR Playbook.
- OT/ICS/SCADA environments — requires specialized OT IR procedures.
- Supply chain or third-party compromise — requires Third-Party Risk Playbook.
- Linux/macOS malware — MITRE mappings and investigation procedures differ significantly.

14.3 Dependencies

Dependency	If Unavailable	Mitigation
SIEM operational	Investigation severely impaired	Use endpoint logs directly; activate backup monitoring
EDR deployed on endpoint	Limited behavioral visibility	Rely on Sysmon + Windows Event logs
Threat intel feeds active	IOC correlation not possible	Use manual lookups on VirusTotal/OTX
Escalation contacts current	Delayed L2/L3 notification	Maintain physical backup contact list
Forensic toolkit available	Memory/disk acquisition not possible	Document gap; proceed with available tools
Clean backup available	System restoration compromised	Rebuild from installation media; accept data loss

14.4 Known Limitations

- Encrypted C2 (T1573) detection capability is currently LOW — this is the most significant detection gap. Until improved, assume C2 activity may be present in all High/Critical incidents even without confirmed indicators.
- Fileless malware detection depends entirely on Sysmon and PowerShell ScriptBlock logging being enabled. If these are not deployed, fileless malware may not be detectable until active harm is observed.
- This playbook assumes English-language interfaces and Windows-centric environments. Adaptation required for Arabic-interface systems or mixed OS environments.
- SLA targets assume adequate analyst staffing levels. During staff shortage, SLAs must be formally suspended and management notified.

15. Continuous Improvement

A playbook that is not regularly updated becomes a liability rather than an asset. This section documents the processes by which this playbook and associated detection capabilities are maintained, validated, and improved over time.

15.1 Review Cycle

Review Type	Trigger	Owner	Output
Post-Incident Review	Every High/Critical incident closure	Incident Commander	Lessons Learned Report + Action Plan
Monthly Review	1st Monday of each month	SOC Lead	KPI report + Rule tune log
Quarterly Review	End of each quarter	SOC Lead + TI	Playbook version update if required
Annual Review	January each year	CISO + SOC Lead	Full playbook revalidation
Emergency Review	Major new threat actor / Zero-day	SOC Lead	Expedited playbook update

15.2 Lessons Learned Process

8. Incident is closed by the Incident Commander.
9. PIR meeting is scheduled within 72 hours — all response participants attend.
10. PIR facilitator (SOC Lead) presents incident timeline and asks: What happened? What worked? What failed? What must change?
11. All identified gaps are documented with: Gap description, Category (People/Process/Technology), Corrective Action, Owner, Deadline.
12. Corrective actions are tracked in a shared action tracker — reviewed monthly.
13. Lessons Learned Report is distributed to all SOC personnel, CISO, and relevant IT management.
14. If a procedure gap is identified, the playbook is updated and a new version is issued within 30 days.

15.3 Detection Engineering Feedback Loop

Every malware incident generates detection intelligence that must be operationalized:

- New IOCs (hashes, IPs, domains) → Added to SIEM blocklists and threat intel repository.
- Confirmed attack techniques → SIEM rules created or tuned for the specific technique variant.
- False positives identified → SIEM rules refined to reduce noise.
- ATT&CK coverage gaps identified → Detection rule development backlog updated.
- New malware behaviors observed → YARA signatures developed for future identification.

TIP

DETECTION ENGINEERING STANDARD: Every incident should result in at least one new or improved detection rule. If an analyst cannot identify a detection improvement after an incident, this indicates either an incomplete post-incident review or a missed opportunity.

16. Frequently Asked Questions

This section provides answers to questions commonly raised by SOC analysts during malware incident response. Questions are organized to reflect typical analyst decision points during the response lifecycle.

Q1	When should I create an incident ticket?
	Immediately upon receiving an alert that is not immediately and conclusively a false positive. The ticket must be created BEFORE investigation begins — it is the official record of all subsequent actions.

Q2	What is the difference between L1 and L2 investigation?
	L1 performs initial triage: validating the alert, checking IOCs against threat intel, and determining if escalation is warranted using the decision tree. L2 performs deep investigation: sandbox analysis, memory forensics, scope assessment, full timeline reconstruction, and remediation planning.

Q3	What do I do if I can't reach the L2/L3 on-call?
	Document the attempt in the ticket with timestamp. Try the next contact in the escalation directory. If unavailable, escalate to the CISO emergency contact. Never delay containment of a Critical incident due to escalation communication failures — execute immediate containment and document.

Q4	Should I isolate the host before or after RAM capture?
	AFTER RAM capture, whenever operationally possible. The order of operations is: (1) RAM capture, (2) Hash the RAM dump, (3) Transfer to evidence storage, (4) Execute network isolation. Exception: if active exfiltration is occurring and isolation will stop it, prioritize isolation and accept the RAM evidence loss.

Q5	When is it appropriate to close an alert as a false positive?
	Only when: (a) the alert source is on the verified whitelist AND the alert behavior matches the expected behavior for that source, OR (b) investigation confirms with high confidence that no malicious activity occurred. Document the specific reason for the false positive decision in the ticket.

Q6	How do I handle a suspected fileless malware infection?
	Fileless malware lives in memory and leaves no disk artifacts. Key steps: (1) Do NOT reboot — this destroys all evidence. (2) Capture RAM immediately using WinPmem or FTK Imager. (3) Analyze RAM with Volatility 3 (windows.malfind, windows.pslist). (4) Review PowerShell ScriptBlock logs and Sysmon events for encoded commands.

Q7	What is beaconing and how do I detect it?
	Beaconing is the regular, periodic outbound connection from an infected host to a C2 server. Detection: Query SIEM for connections from the affected host to external IPs over a 24-hour

period and look for connections occurring at regular intervals (every 60, 300, or 600 seconds is common). A connection that occurs like clockwork is not normal user behavior.

Q8	When must I notify Legal?
	Whenever there is confirmed or strongly suspected data exfiltration. Do not wait for certainty — notify Legal as soon as exfiltration is a credible possibility. Early notification allows Legal to begin privilege assessment and prepare for potential regulatory notification requirements.

Q9	Can I submit malware samples to VirusTotal?
	Submit HASHES only to public VirusTotal — not files. Submitting files to public VT makes them available to all VT users and could expose sensitive data embedded in the malware. If you need full file submission for sandbox analysis, use a private VT Intelligence account or Any.run with appropriate privacy settings.

Q10	What is the difference between containment and eradication?
	Containment stops the active attack and prevents spread — the malware is still present on the system but cannot communicate or propagate. Eradication is the complete removal of all malicious artifacts. Never proceed to Recovery without completing Eradication — containment alone is not sufficient.

Q11	How long should I monitor a recovered system?
	Minimum 72 hours of enhanced SIEM monitoring post-recovery. For Critical incidents or incidents involving ransomware droppers, extend monitoring to 7 days. Enhanced monitoring means: all events from the recovered system are reviewed daily, not just alert-triggered.

Q12	What if the same user is infected multiple times?
	Multiple reinfections indicate either: (a) incomplete eradication (a persistence mechanism was missed), (b) the user's behavior is creating repeated exposure (targeted phishing, insecure browsing), or (c) a credential compromise that has not been fully resolved. Escalate to L3 and initiate a full forensic investigation of the user's devices and accounts.

Q13	Do I need to follow this playbook if the incident seems minor?
	Yes. The Severity Classification table determines the response level — not your initial impression. Many major incidents begin as 'minor' alerts. Following the decision tree on every alert is what ensures major incidents are identified early and contained quickly.

Q14	What is a Ransomware Dropper and why is it Critical?
	A ransomware dropper is malware designed to deliver and execute a ransomware payload as its final stage. Detection of a dropper (e.g., Emotet delivering Ryuk) gives you a window of opportunity to prevent the ransomware from executing. This window is often very short — hours or minutes. This is why Ransomware Dropper identification immediately triggers Critical severity and war room activation.

Q15	How do I handle an incident that occurs outside business hours?
	Follow the same playbook — severity classification and escalation apply 24/7. The on-call contact list provides 24/7 coverage. SLAs apply regardless of time of day. If the on-call analyst is unavailable, escalate per the backup escalation path in the contact directory.

Q16	What is a WMI Event Subscription and why is it dangerous?
	WMI Event Subscriptions are a persistence mechanism (T1547) where malware registers to execute whenever a specific system event occurs (e.g., system startup, user logon). They are extremely stealthy — they don't appear in Autoruns by default and are often missed during eradication. Use Get-WMIObject or WMIC to enumerate all event subscriptions during every eradication phase.

Q17	When should I consider full forensic investigation vs. targeted remediation?
	Full forensic investigation is recommended when: (a) Critical severity with confirmed C2 and/or lateral movement, (b) data exfiltration is suspected or confirmed, (c) the incident involves a privileged account, (d) legal action is anticipated, or (e) this is part of a suspected coordinated attack campaign. Targeted remediation is appropriate for contained, isolated infections with no spread indicators.

Q18	How do I validate that eradication is complete?
	Eradication validation requires: (1) Full AV/EDR scan on the affected system and all systems in the investigation scope — clean results required. (2) Autoruns review showing no malicious persistence entries. (3) Network monitoring showing no further C2 beaconing. (4) Registry review of key run keys. (5) Formal sign-off by the Incident Commander.

Q19	What should I do if containment actions cause business disruption?
	Immediately notify the Incident Commander, who will notify CISO and relevant business stakeholders. Document the disruption in the incident ticket. The business impact of containment must be weighed against the risk of continued infection spread — this is a management decision, not an analyst decision. Never reverse containment actions without IC authorization.

Q20	How do I access the threat intelligence feeds referenced in the playbook?
	Verify access with your SOC Lead during onboarding: VirusTotal (web browser or API key), AlienVault OTX (API key configured in SIEM), internal IOC repository (SIEM threat intel module or TIP platform). Access credentials must be stored in the team password manager — never in personal notes or local files.

17. Glossary

The following terms are used throughout this documentation package and the associated playbook. All SOC personnel are expected to be familiar with these terms prior to their first shift.

Term	Definition
ATT&CK (MITRE)	Adversarial Tactics, Techniques, and Common Knowledge. A globally-accessible knowledge base of adversary tactics and techniques based on real-world observations, maintained by MITRE Corporation.
Backdoor	A type of malware that provides covert, unauthorized access to a system, bypassing normal authentication mechanisms.
Beaconing	Periodic, regular outbound network communication from an infected host to a C2 server, used by the attacker to maintain communication and receive commands.
C2 (Command & Control)	Infrastructure used by threat actors to remotely control malware-infected systems. C2 channels receive commands and exfiltrate stolen data.
Chain of Custody	A documented, unbroken record of evidence collection, handling, transfer, and storage from the point of acquisition through final disposition.
Correlation Rule	A SIEM rule that combines multiple log events to identify patterns indicative of malicious activity that individual events would not reveal.
DFIR	Digital Forensics and Incident Response — the discipline combining forensic investigation techniques with incident response procedures.
Drive-by Compromise (T1189)	Malware delivery method in which a user visits a compromised website that automatically executes a browser exploit to deliver a payload without user interaction.
EDR	Endpoint Detection and Response — security software providing real-time monitoring, threat detection, and response capability on endpoints.
Emotet	A prolific Trojan malware family that began as a banking trojan and evolved into a dropper delivering secondary payloads such as TrickBot and Ryuk ransomware.
Fileless Malware	Malware that executes entirely in system memory and uses legitimate system tools (PowerShell, WMI, certutil) rather than writing files to disk, making it harder to detect with traditional AV.
FTK Imager	Forensic Toolkit Imager — a free forensic acquisition tool by AccessData (now Exterro) for capturing disk images and RAM dumps with hash verification.
HKCU / HKLM	HKEY_CURRENT_USER / HKEY_LOCAL_MACHINE — Windows Registry hive locations frequently abused by malware for persistence via Run key entries.
IOC	Indicator of Compromise — forensic artifacts (file hashes, IP addresses, domains, registry keys) that indicate a system has been compromised.
IPS	Intrusion Prevention System — a network security system that monitors network traffic and blocks suspicious activity based on signatures and behavioral rules.

Lateral Movement	Techniques used by attackers to progressively move through a network environment after initial compromise, seeking additional systems and elevated privileges.
LOLBins	Living-Off-the-Land Binaries — legitimate Windows system binaries abused by malware to execute malicious code (e.g., PowerShell, certutil, mshta, regsvr32).
MTTD	Mean Time to Detect — the average time between an actual infection/event occurring and the SOC generating an alert for it.
MTTR	Mean Time to Respond/Remediate — the average time between incident identification and full remediation/closure.
NIST SP 800-61r2	National Institute of Standards and Technology Special Publication 800-61 Revision 2 — the primary US government standard for computer security incident handling.
PIR	Post-Incident Review — a structured meeting held after incident closure to identify lessons learned and drive process improvement.
Persistence	Techniques used by malware to maintain access to a system across reboots, user logouts, or other interruptions (e.g., Registry Run keys, Scheduled Tasks, Services).
Process Injection (T1055)	Technique where malware injects malicious code into a running legitimate process to hide its presence and inherit the process's security context.
RACI	Responsible, Accountable, Consulted, Informed — a project management framework for defining roles and responsibilities for activities.
RAM Dump	A complete binary copy of a system's random access memory (RAM) captured at a specific point in time for forensic analysis.
RAT	Remote Access Trojan — malware providing unauthorized remote control capability over an infected system, typically including file access, webcam control, and remote shell.
Rootkit	Malware designed to conceal its presence and the presence of other malware from the operating system and security tools, often operating at the kernel level.
SIEM	Security Information and Event Management — a platform that aggregates log data from across an organization's environment, correlates events, and generates alerts for security analysis.
SLA	Service Level Agreement — a documented commitment to respond to or resolve an issue within a specified timeframe.
Spearphishing (T1566)	A targeted phishing attack where malicious emails are crafted specifically for the intended recipient using personal or organizational information to increase credibility.
Sysmon	System Monitor — a free Windows system service by Microsoft Sysinternals that provides enhanced endpoint telemetry including detailed process, network, and registry logging.
TTP	Tactics, Techniques, and Procedures — the behavioral characteristics of a threat actor, as codified in frameworks like MITRE ATT&CK.
Volatility 3	An open-source Python memory forensics framework for analyzing RAM dumps to extract running processes, network connections, loaded modules, and injected code.

VLAN Quarantine	A network isolation technique where an infected host is moved to a separate, restricted VLAN through a firewall or switch configuration, limiting its ability to communicate with the production network.
Worm	Self-replicating malware that spreads across networks without requiring user interaction, typically exploiting vulnerabilities in network services.
YARA	Yet Another Recursive Acronym — a tool for writing pattern-matching rules to identify and classify malware samples based on strings, byte patterns, or behavioral characteristics.

18. Appendices

Appendix A — Master Incident Response Checklist

Use this checklist for every malware incident. Check each item as completed. Document the timestamp and analyst name in the incident ticket.

A.1 — Initial Triage (L1 — Target: < 10 minutes)

- Alert received and acknowledged in ticketing system
- Alert source checked against whitelist
- Incident ticket created with: Incident ID, Date/Time (UTC), Affected Host, Alert Source, Initial Description
- File hashes / IPs / Domains checked against threat intelligence feeds
- SIEM queried for events from affected host in the past 24–72 hours
- Decision tree applied — all 7 questions answered and documented
- Initial severity classification assigned
- Screenshot of SIEM alert captured and attached to ticket

A.2 — Escalation (L1 → L2)

- L2 analyst notified via defined escalation channel (phone + ticket)
- Escalation timestamp documented in ticket
- Initial findings summary provided to L2 in ticket or verbal brief
- Severity level confirmed or revised by L2

A.3 — Investigation (L2 — Target: varies by severity)

- RAM capture authorized and executed BEFORE isolation
- RAM dump SHA256 hash computed and documented
- RAM dump transferred to secure evidence storage
- Chain of custody record initiated for RAM dump
- Malware samples submitted to sandbox (Any.run / Hybrid Analysis)
- Sandbox analysis results documented in ticket
- Full scope assessment completed — all affected systems identified
- Attack timeline constructed in ticket (chronological, UTC timestamps)
- MITRE ATT&CK techniques mapped and documented
- IOCs collected across all 6 categories (File, Network, Host, Memory, Log, Email)
- Forensic investigation decision made (full vs. targeted)
- Remediation plan documented and approved by Incident Commander

A.4 — Containment

- Host isolated via VLAN quarantine (not power-off)
- Affected user account disabled in Active Directory

- Malicious IPs and domains blocked at firewall
- Network block documented with timestamp and specific IPs/domains
- Stakeholders notified of containment actions and business impact
- All containment actions logged in incident ticket with UTC timestamps

A.5 — Eradication

- Full AV/EDR scan completed on infected host — results documented
- Full AV/EDR scan completed on all systems in scope — results documented
- Autoruns review completed — all malicious entries removed and documented
- Registry Run keys checked and cleaned (HKLM and HKCU)
- Scheduled Tasks reviewed and malicious tasks removed
- Malicious Windows Services removed
- WMI Event Subscriptions reviewed and malicious subscriptions removed
- Credentials reset for all accounts that accessed the infected system
- Attacker-created accounts removed
- Security patches applied for exploited vulnerabilities
- Eradication validated and signed off by Incident Commander

A.6 — Recovery

- System reimaged from verified clean baseline image
- Data restored from backup — backup timestamp predates infection confirmed
- Data integrity verified by hash comparison
- All pending security patches applied before reconnection
- Full AV/EDR validation scan completed — clean
- System reconnected to production network
- Enhanced SIEM monitoring activated — 72-hour monitoring period
- Business stakeholders notified of system restoration
- Normal business operations confirmed

A.7 — Post-Incident

- Incident ticket fully updated — all actions documented
- Incident formally closed by Incident Commander
- PIR meeting scheduled within 72 hours
- PIR meeting held — all participants attended
- Lessons Learned Report drafted
- Corrective actions assigned with owners and deadlines
- Final Incident Report drafted using Incident Report Template
- Final report reviewed and approved by Incident Commander
- Final report distributed to: CISO, SOC Lead, relevant stakeholders
- SIEM detection rules updated based on incident findings
- Playbook updated if procedure gaps identified
- Regulatory notification assessed and completed if required

Appendix B — Daily Analyst Shift Checklist

Complete at the START and END of every shift.

Shift Start

- Review open incident tickets — verify all are current and actioned
- Review SIEM dashboard — confirm all sensors reporting, no processing lag
- Check threat intelligence feeds for new high-priority IOCs or advisories
- Review escalation contact list — confirm on-call contacts for the shift
- Receive shift handover brief from outgoing analyst — all open incidents briefed

Shift End

- All open incidents updated with current status in ticket system
- Any new IOCs from shift activities added to threat intel repository
- Shift handover brief prepared for incoming analyst
- Any anomalies or concerns not yet resolved — documented and briefed
- SIEM alert queue reviewed — no unacknowledged alerts remaining

Appendix C — Analyst Quick Reference Card

Print this card and keep it at your workstation.

SEVERITY → RESPONSE	ESCALATION → CONTACT
🔴 **CRITICAL: < 15 min — L3 + Mgmt** 🟠 **HIGH: < 1 hour — L2/L3** 🟡 **MEDIUM: < 4 hours — L2** 🟢 **LOW: < 24 hours — L1**	Active C2 → Incident Commander Lateral Movement → SOC Lead + L3 Exfiltration → L3 + CISO + Legal **Ransomware Dropper → L3 + WAR ROOM**
FIRST 10 MINUTES — L1 ACTIONS	**NEVER DO DURING INCIDENT**
1. Screenshot the alert 2. Create the ticket 3. Check whitelist 4. IOC lookup (VT/OTX) 5. SIEM query (24h scope) 6. Apply decision tree 7. Escalate with SLA	❌ Reboot before RAM capture ❌ Isolate before RAM capture (fileless) ❌ Delete alert data ❌ Skip ticket creation ❌ Delay escalation for 'more info' ❌ Submit sensitive files to public VT ❌ Reverse containment without IC auth

— END OF DOCUMENT —

INCIDENT RESPONSE PLAYBOOK
Malware Infection

MITRE ATT&CK v14 | NIST SP 800-61r2 | With Decision Tree

Classification	Public Release
Version	1.0 — Initial Release
Author	BlueShield Team
Date	June 2026
Framework	MITRE ATT&CK v14 + NIST SP 800-61r2
Incident Type	Malware Infection

1. Playbook Overview

1.1 Purpose

This playbook provides a structured, step-by-step guide for detecting, containing, eradicating, and recovering from Malware Infection incidents. It is designed for SOC Analysts, Incident Responders, and IT Security teams working within environments monitored by SIEM platforms such as SIEM.

1.2 Malware Definition

Malware is malicious software designed to harm, disrupt, or gain unauthorized access to computers, servers, or networks. It includes viruses, worms, trojans, ransomware, spyware, rootkits, botnets, keyloggers, cryptominers, and other malicious code. Malware is often used in cyberattacks to steal data, disrupt operations, maintain persistence, or evade detection within targeted systems.

1.3 Scope

- Endpoints: Workstations, Servers, Laptops
- Network segments visible to SIEM
- Malware types: Trojans, Worms, Spyware, Ransomware-droppers, RATs, Backdoors
- Excludes: Full Ransomware encryption events (separate playbook)

1.4 Severity Classification

Severity	Criteria	Response SLA	Escalation
Critical	Active C2, lateral movement, data exfiltration	Immediate (< 15 min)	L3 + Management
High	Confirmed infection, no spread detected	< 1 hour	L2/L3
Medium	Suspicious indicators, unconfirmed infection	< 4 hours	L2
Low	Potentially unwanted software (PUP)	< 24 hours	L1

2. Roles & Responsibilities

Role	Responsibility
SOC Analyst (L1)	First responder: triage alerts, initial investigation, log collection
SOC Lead / L2 Analyst	Deep investigation, malware analysis, threat correlation, MITRE mapping
Incident Commander (L3)	Oversees response, authorizes containment, manages escalation
IT / Sysadmin Team	Executes isolation, patch deployment, system reimaging
Threat Intelligence	Identifies malware family, IOCs, TTPs from threat feeds
Management / CISO	Business decisions, external communications, legal considerations

3. Incident Response Phases

This playbook follows the NIST SP 800-61r2 Incident Response Lifecycle adapted for Malware Infection scenarios.

1 PREPARATION

Phase Objective

Establish the people, processes, and technologies required to effectively detect, respond to, and recover from malware incidents while minimizing business impact.

Preparation Activities

Security Controls & Monitoring

- Ensure Anti-Malware and EDR solutions are deployed, updated, and monitored.
- Enable centralized logging and SIEM monitoring across critical systems.
- Configure detection rules for malware execution, persistence, C2 activity, lateral movement, and data exfiltration.
- Maintain secure backups and an up-to-date asset inventory.

Incident Response Readiness

- Maintain and regularly review incident response procedures and escalation paths.
- Define roles, responsibilities, and communication channels.
- Ensure access to critical documentation and forensic tools.
- Establish evidence preservation and chain-of-custody procedures.

Threat Intelligence

- Monitor threat intelligence feeds and security advisories.
- Maintain IOC repositories and update detection content.
- Incorporate lessons learned from previous incidents.

Security Awareness & Training

- Conduct regular security awareness training and phishing simulations.
- Perform tabletop exercises to validate incident response readiness.

Key Deliverables

- Active Security Monitoring
- Updated Incident Response Procedures
- Defined Escalation Process
- Current Threat Intelligence Sources
- Trained Personnel
- Tested Backup and Recovery Capabilities

2 Detection

Phase Objective

The objective of this phase is to detect, validate, and classify malware-related incidents, determine the scope and impact of the infection, and initiate the appropriate incident response process.

Detection Activities

- Monitor security alerts from SIEM, EDR, Anti-Malware, IDS/IPS, and user reports.
- Validate alerts to determine whether malicious activity is present.
- Create or update an incident ticket and document all findings.
- Classify the incident severity based on affected assets, business impact, and infection scope.
- Escalate confirmed or suspected malware incidents according to the Incident Response Plan.

Initial Investigation

- Identify affected hosts, users, accounts, and applications.
- Determine the malware infection vector (email, web download, removable media, exploit, etc.).
- Assess the scope of the compromise and identify any signs of propagation.
- Review endpoint, network, authentication, and security logs for related activity.
- Collect and preserve relevant evidence, including:
    - File hashes
    - Malicious files
    - Process information
    - Network connections
    - System and security logs
- Correlate findings with threat intelligence sources and known IOCs.
- Determine whether additional systems may be affected.

Incident Assessment

- Confirm the malware type and attack characteristics where possible.
- Evaluate potential impacts to confidentiality, integrity, and availability.
- Assess indicators of:
    - Persistence
    - Command-and-Control (C2) communication
    - Privilege escalation
    - Lateral movement
    - Data exfiltration
- Reassess incident severity and update response actions accordingly.

Escalation Criteria

Immediately escalate the incident if any of the following are identified:

- Active malware spreading across multiple systems.
- Confirmed Command-and-Control (C2) activity.
- Privileged account compromise.
- Critical server or business system affected.
- Evidence of data theft or exfiltration.
- Ransomware or malware dropper activity.

Key Deliverables

- Incident Ticket Created
- Initial Scope Assessment
- Evidence Preserved
- Malware Classification
- Severity Determination
- Escalation Decision
- IOC Collection

3 Analysis

Phase Objective

The objective of this phase is to determine the scope, impact, and root cause of the malware incident, identify affected assets, and develop an effective containment and remediation strategy.

Analysis Activities

Malware Analysis

- Identify the malware family, type, and capabilities using threat intelligence platforms, sandbox analysis, and security tools.
- Validate Indicators of Compromise (IOCs) including file hashes, IP addresses, domains, URLs, and registry artifacts.
- Determine malware persistence mechanisms and execution methods.

Scope Assessment

- Establish a timeline of malicious activity and key events.
- Identify affected systems, users, accounts, and applications.
- Assess whether the malware has spread to additional hosts.
- Determine the initial infection vector and attack path.

Impact Analysis

- Evaluate potential impacts to confidentiality, integrity, and availability.
- Identify evidence of:
  - Persistence
  - Privilege Escalation
  - Lateral Movement
  - Command-and-Control (C2) Communication
  - Data Exfiltration
- Assess potential business and operational impact.

Threat Intelligence & Forensics

- Correlate findings with threat intelligence sources and known malware campaigns.
- Preserve relevant evidence for forensic investigation and legal requirements.
- Determine whether a full forensic investigation is required based on incident severity and business impact.

Remediation Planning

- Verify that affected assets remain isolated.
- Identify containment and eradication requirements.
- Develop a remediation plan based on the scope and findings of the investigation.

Key Deliverables

- Malware Classification
- Incident Timeline
- Scope Assessment
- Impact Assessment
- IOC Validation
- Forensic Investigation Decision
- Remediation Plan

4 Remediation (Containment, Eradication & Recovery)

Phase Objective

The objective of this phase is to contain the malware infection, eradicate malicious artifacts from the environment, and safely restore affected systems and services to normal business operations.

Containment

- Isolate infected or suspected systems from the network.
- Identify and monitor additional potentially affected assets.
- Block malicious IP addresses, domains, URLs, and Command-and-Control (C2) communications.
- Disable or restrict compromised accounts and enforce password resets and MFA where applicable.
- Preserve critical evidence, including malware samples, logs, and forensic artifacts.
- Communicate containment status to relevant stakeholders.

Eradication

- Remove malware using approved security tools and remediation procedures.
- Eliminate persistence mechanisms, malicious services, scheduled tasks, registry modifications, and unauthorized accounts.
- Reimage systems when integrity cannot be verified.
- Apply security patches and remediate exploited vulnerabilities.
- Reset credentials associated with affected systems and users.
- Validate that all Indicators of Compromise (IOCs) have been removed.

Recovery

- Restore affected systems and data from trusted backups where required.
- Reconnect remediated systems to the production environment.
- Restore business services based on operational priority and business impact.
- Perform full malware and security validation scans before returning systems to service.
- Monitor systems closely for signs of reinfection or suspicious activity.
- Confirm normal business operations have been restored.

Key Deliverables

- Malware Contained
- Malicious Artifacts Removed
- Compromised Accounts Remediated
- Systems Restored
- Services Returned to Operation

  Enhanced Monitoring Enable

5 Post-Incident Activities

Phase Objective

The objective of this phase is to document the incident, identify lessons learned, improve security controls, and implement corrective actions to reduce the likelihood and impact of future malware incidents.

Post-Incident Activities

Incident Reporting

- Prepare a final incident report detailing:
  - Incident timeline
  - Root cause
  - Scope and impact
  - Containment and remediation actions
  - Recovery activities
  - Recommendations for improvement
- Submit the report to relevant stakeholders and management.

Lessons Learned & Continuous Improvement

- Conduct a post-incident review meeting with all relevant teams.
- Identify gaps in people, processes, and technology.
- Document lessons learned and track improvement actions.
- Update detection rules, response procedures, and playbooks based on findings.
- Perform root cause analysis and remediate underlying weaknesses.

Security Enhancements

- Review and improve monitoring, alerting, and incident response capabilities.
- Update threat intelligence, IOC repositories, and security controls.
- Implement additional safeguards where required to prevent recurrence.

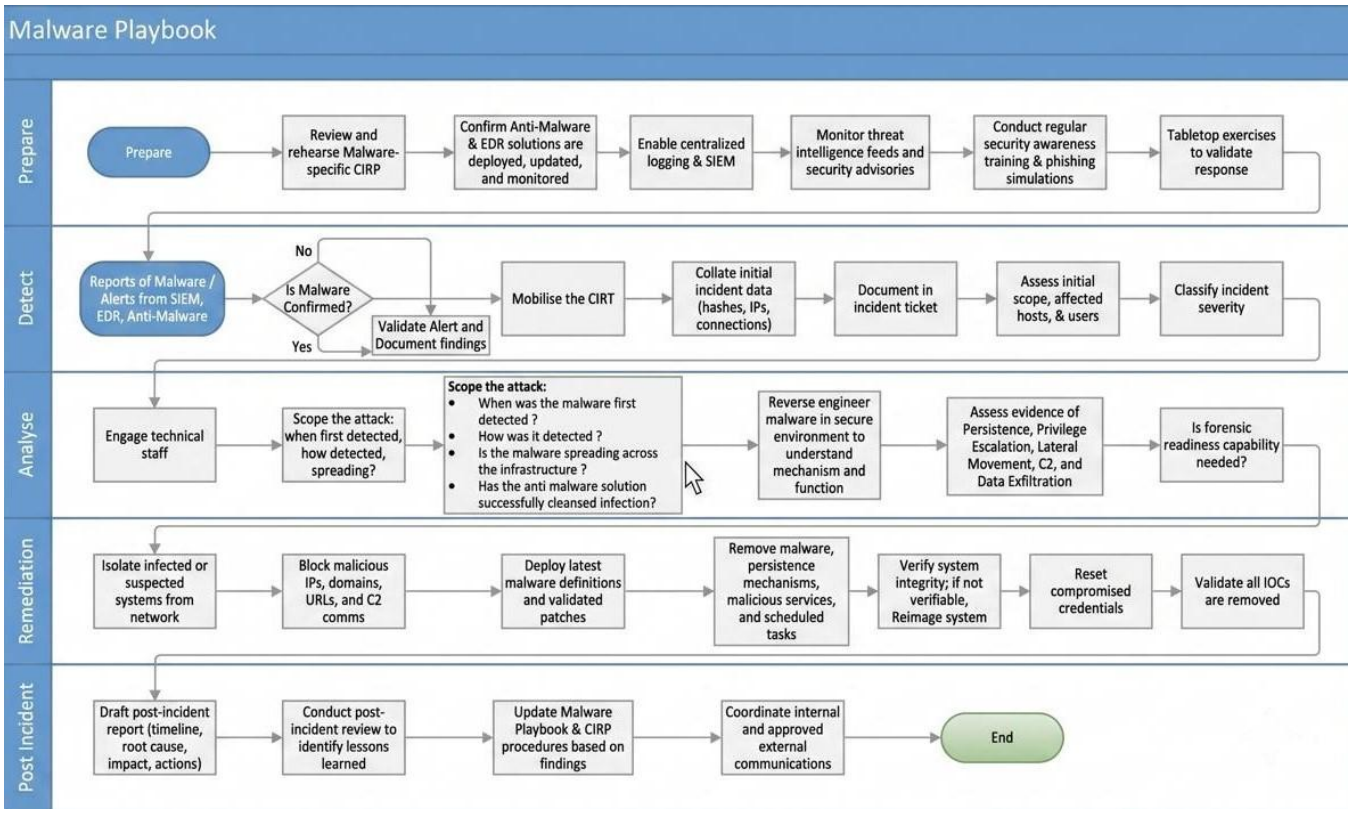
Communications & Compliance

- Provide internal communications and awareness updates where appropriate.
- Fulfill regulatory, legal, or contractual reporting requirements if applicable.
- Coordinate approved external communications through designated management and communications teams.

Key Deliverables

- Final Incident Report
- Root Cause Analysis
- Lessons Learned Report
- Updated Detection Rules
- Updated Playbook & Procedures
- Corrective Action Plan

4. Flow Diagram



5. Analyst Decision Tree

Use this decision tree when an alert fires. Follow each question top-to-bottom to determine the correct response action.

#	Question / Condition	YES → Action	NO → Action
1	Is the alert from a known-good (whitelisted) source?	Close as False Positive. Document reason.	Proceed to Q2
2	Is there matching IOC (hash/IP/domain) in Threat Intel feeds?	Escalate to L2. Open High severity ticket.	Proceed to Q3
3	Is there evidence of process injection or unusual parent-child process?	Confirm infection. Isolate host immediately.	Proceed to Q4
4	Is there outbound network traffic to suspicious IPs/domains?	Confirm C2 activity. Block at Firewall. Escalate to Critical.	Proceed to Q5
5	Are there persistence mechanisms (registry/scheduled tasks/services)?	Confirmed persistent infection. Begin Eradication phase.	Proceed to Q6
6	Is there evidence of lateral movement (logons to other hosts)?	Escalate to Critical. Isolate network segment. Notify L3.	Assign Medium. Deep investigation required.
7	Is there evidence of data exfiltration (large outbound transfers)?	Escalate to Critical. Preserve evidence. Notify CISO + Legal.	Proceed with standard Eradication + Recovery.

Response Level Summary:

Condition Met	Severity	Owner	SLA
IOC match + C2 + Lateral Movement	Critical	L3 + Management	Immediate
IOC match + Persistence (no C2)	High	L2/L3	< 1 hour
Suspicious indicators, no IOC match	Medium	L2	< 4 hours
False positive confirmed	Informational	L1	Document only

6. MITRE ATT&CK Mapping

The following tables map common Malware Infection behaviors to the MITRE ATT&CK Enterprise framework (v14).

6.1 Initial Access

Tactic	Technique	ID	Description	Detection in SIEM
Initial Access	Spearphishing Attachment	`T1566.001`	Malware via malicious email attachment (macro-enabled Office, PDF exploit)	*Email gateway alerts, Office spawning cmd.exe/powershell.exe*
Initial Access	Drive-by Compromise	`T1189`	User visits compromised website, browser exploit delivers payload	*Unusual browser child processes, new files in %TEMP%/%APPDATA%*
Initial Access	Valid Accounts	`T1078`	Attacker uses stolen credentials to authenticate and deploy malware	*Logins from unusual geo/time, auth failures then success*
Initial Access	Exploit Public-Facing App	`T1190`	Malware via exploitation of unpatched internet-facing application	*IDS/IPS alerts, unusual app behavior, error spikes*

6.2 Execution

Tactic	Technique	ID	Description	Detection in SIEM
Execution	PowerShell	`T1059.001`	Malware uses PowerShell to download/execute payloads, often encoded	*PowerShell encoded commands, ScriptBlock logging, execution policy bypass*
Execution	Windows Command Shell	`T1059.003`	cmd.exe used to run malicious scripts, copy payloads, spawn processes	*cmd.exe spawned by Office/Browser, suspicious command strings*
Execution	WMI	`T1047`	WMI used to execute code and maintain persistence via event subscriptions	*WMI activity logs, new EventFilter/EventConsumer subscriptions*
Execution	User Execution: Malicious File	`T1204.002`	User double-clicks malicious attachment, directly executing malware	*New process from Downloads/Temp, email attachment opens*

6.3 Persistence

Tactic	Technique	ID	Description	Detection in SIEM
Persistence	Registry Run Keys	`T1547.001`	Malware adds itself to HKLM/HKCU Run keys or Startup folder	*Sysmon Event 13 (registry mod), new Run key entries from non-standard paths*
Persistence	Scheduled Task	`T1053.005`	Malware creates scheduled tasks to re-execute at intervals	*Sysmon Event 1 (schtasks.exe), new tasks in non-standard locations*
Persistence	Create/Modify System Process	`T1543.003`	Malware installs as Windows Service to run with system privileges	*New service events (Event ID 7045), services from unusual paths*

6.4 Defense Evasion

Tactic	Technique	ID	Description	Detection in SIEM
Defense Evasion	Masquerading	`T1036`	Malware names itself after legitimate processes (svchost.exe, lsass.exe)	*Process running from non-standard path, parent-child anomalies*
Defense Evasion	Obfuscated Files	`T1027`	Payloads encoded in Base64/XOR or packed to evade AV signatures	*High entropy file writes, encoded PowerShell, AMSI bypass attempts*
Defense Evasion	Disable Security Tools	`T1562.001`	Malware disables Defender, Firewall, event logging to hinder detection	*Security service stopped, Event ID 1102 (log cleared), audit policy changes*
Defense Evasion	Process Injection	`T1055`	Malware injects code into legitimate processes (explorer.exe, lsass.exe)	*Sysmon Event 8 (CreateRemoteThread), unusual memory writes*

6.5 Command & Control

Tactic	Technique	ID	Description	Detection in SIEM
C2	Application Layer: Web	`T1071.001`	Malware uses HTTP/HTTPS to blend C2 with normal web traffic	*Beaconing patterns, HTTP to non-categorized domains, new DNS queries*
C2	DNS Tunneling	`T1071.004`	Malware encodes data in DNS queries/responses to exfiltrate or receive commands	*High-volume DNS queries, unusually long query strings, uncommon TLDs*
C2	Encrypted Channel	`T1573`	Malware uses encrypted communication to hide C2 traffic	*Certificate anomalies (self-signed/expired), unexpected encrypted patterns*

7. MITRE ATT&CK Coverage Heatmap

This heatmap visualizes detection coverage for each mapped technique. Use it to identify gaps in your SIEM rules and detection capabilities.

Legend: HIGH Coverage | MEDIUM Coverage | LOW Coverage

Technique	SIEM Alert	Log Source	EDR Rule	Network Block	Coverage
T1566 Spearphishing	HIGH	HIGH	MED	—	HIGH
T1189 Drive-by	MED	MED	LOW	MED	MED
T1059 PowerShell	HIGH	HIGH	HIGH	—	HIGH
T1047 WMI	MED	MED	MED	—	MED
T1547 Registry Run	HIGH	HIGH	HIGH	—	HIGH
T1053 Sched. Task	HIGH	HIGH	MED	—	HIGH
T1036 Masquerading	MED	MED	HIGH	—	MED
T1055 Proc. Injection	MED	MED	HIGH	—	MED
T1562 Disable Tools	HIGH	HIGH	MED	—	HIGH
T1071 C2 HTTP/DNS	HIGH	HIGH	—	HIGH	HIGH
T1573 Encrypted C2	LOW	MED	—	MED	LOW
T1078 Valid Accounts	MED	HIGH	—	—	MED

Gap Analysis: Encrypted C2 (T1573) and Drive-by (T1189) show LOW EDR coverage — prioritize rule development for these techniques in the next SIEM tuning cycle.

8. Malware Type Quick-Reference Cheat Sheet

Use this reference during Identification phase to quickly profile the malware type based on observed behavior.

Type	Examples	How It Spreads	Key Indicators	First Response
Trojan	Emotet, TrickBot, AgentTesla	Email attachment, malicious download, fake software	Unexpected network connections, keylogger activity, data staging in %TEMP%	Isolate host, capture RAM, block C2 IPs
Worm	WannaCry (pre-ransom), Conficker	Network shares (SMB), removable drives, email self-replication	High network traffic, SMB errors, multiple hosts infected simultaneously	Isolate entire VLAN, disable SMB if needed, patch MS17-010
RAT (Remote Access Trojan)	DarkComet, NjRAT, AsyncRAT	Phishing, pirated software, drive-by downloads	Persistent outbound connections, webcam/mic activation, remote shell activity	Block C2, disable user account, full forensic analysis
Spyware	Pegasus (mobile), RedLine Stealer	Malicious ads, bundled with freeware, phishing links	Browser credential theft, clipboard monitoring, keylogging, crypto wallet theft	Collect evidence first, reset all credentials, notify affected users
Ransomware Dropper	Emotet dropping Ryuk, TrickBot dropping Conti	Phishing, RDP brute force, supply chain	Dropper stage: PowerShell downloads, reconnaissance commands run before encryption	Stop immediately — do NOT wait for encryption to start. Isolate + escalate to Critical
Fileless Malware	PowerShell Empire, Cobalt Strike	Office macro, memory injection, LOLBins	No files on disk, lives in memory/registry, uses legitimate tools (PowerShell, WMI, certutil)	RAM capture essential. Sysmon + PowerShell logging critical for detection
Rootkit	ZeroAccess, Necurs	Trojan dropper, bootkit, kernel exploit	Hidden processes, disabled AV, BSOD on AV scan, boot-time persistence	May require offline analysis or OS reinstall — do NOT trust the OS after rootkit

9. IOC Collection Checklist

IOC Category	Examples	Collection Method
File-Based	MD5/SHA256 hashes, file names, paths, sizes	FTK Imager, PowerShell Get-FileHash, EDR
Network	C2 IPs, malicious domains, ports, contacted URLs	SIEM, Firewall logs, Wireshark
Host-Based	Registry keys, scheduled tasks, new services, mutexes	Sysmon logs, RegShot, Autoruns
Memory	Injected code, suspicious DLLs, network sockets	Volatility, Rekall, RAM dump analysis
Log-Based	Event IDs: 4688,4624/25,7045,1102,4698 | Sysmon: 1,3,8,11,13	Windows Event Viewer, SIEM
Email	Sender address, attachment hash, subject, headers	Email gateway, header analysis tools

10. Escalation Matrix

Scenario	Escalate To	Method	Timeframe
Active C2 confirmed	Incident Commander (L3)	Phone + Ticket	Immediately
Malware spreading to multiple hosts	SOC Lead + L3	Phone + Ticket	< 15 minutes
Data exfiltration confirmed	L3 + CISO + Legal	Phone + Email	Immediately
Critical server infected	L2 + IT Manager	Phone + Ticket	< 30 minutes
Ransomware dropper identified	L3 + Management	Phone + War Room	Immediately
Incident unresolved > 4 hours	L3 + CISO	Status Meeting	< 4 hours

11. Tools Reference

Tool	Phase	Purpose	Notes
SIEM	All phases	Central log aggregation, correlation, alerting	Primary SIEM
Firewall	Containment	Network isolation, IP/domain blocking, VLAN quarantine	IPS + App Control enabled
Sysinternals Suite	Identification, Eradication	Process Explorer, Autoruns, TCPView, ProcMon	Free — Microsoft
Volatility 3	Identification	Memory forensics — processes, network connections, injected code	Open Source — Python
VirusTotal / Any.run	Identification	Submit file hashes or live sandbox malware analysis	Web-based
Sysmon	Identification	Enhanced Windows event logging — process, network, registry	Use SwiftOnSecurity config
MITRE ATT&CK Navigator	All phases	Map TTPs, visualize coverage gaps, track attack progression	Free — attack.mitre.org

12. References & Further Reading

12.1 Standards & Frameworks

- NIST SP 800-61 Rev. 2 — Computer Security Incident Handling Guide
  - https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-61r2.pdf
- MITRE ATT&CK Enterprise Matrix v14
  - https://attack.mitre.org/matrices/enterprise/
- SANS Incident Handler's Handbook
  - https://www.sans.org/white-papers/33901/
- CISA Incident Response Guidance
  - https://www.cisa.gov/sites/default/files/publications/NCCIC_ICS-CERT_AAL_Incident_Response.pdf

12.2 Tools Documentation

- FortiSIEM 7.2 Admin Guide — https://docs.fortinet.com/fortisiem
- Volatility 3 Documentation — https://volatility3.readthedocs.io
- Sysmon Configuration (SwiftOnSecurity) — https://github.com/SwiftOnSecurity/sysmon-config
- MITRE ATT&CK Navigator — https://mitre-attack.github.io/attack-navigator/
- Any.run Sandbox — https://any.run/
- AlienVault OTX Threat Intelligence — https://otx.alienvault.com/

12.3 Malware Intelligence Resources

- MalwareBazaar (Abuse.ch) — https://bazaar.abuse.ch/
- VirusTotal Intelligence — https://virustotal.com/
- Hybrid Analysis — https://hybrid-analysis.com/
- Malpedia Malware Encyclopedia — https://malpedia.caad.fkie.fraunhofer.de/

13. Appendix — Incident Report Template

Field	Value
Incident ID	IR-YYYY-XXX
Incident Title	Malware Infection — [System/User Name]
Severity	Critical / High / Medium / Low
Date/Time Detected	YYYY-MM-DD HH:MM (UTC)
Date/Time Resolved	YYYY-MM-DD HH:MM (UTC)
Affected Systems	List of hostnames / IPs
Malware Family / Type	e.g., Emotet, AsyncRAT, Fileless
Initial Vector	Email / Web / USB / RDP / Other
MITRE Tactics Observed	e.g., Initial Access, Execution, Persistence, C2
Containment Actions	Description of actions taken
Eradication Actions	Description of removal steps
Data Exfiltrated?	Yes / No / Unknown — Details if Yes
Root Cause	Technical root cause summary
Recommendations	Actions to prevent recurrence
Analyst Name	Name / Contact
Reviewed By	Incident Commander / SOC Lead